

Ağ Güvenliği: Kapsamlı Bir Teknik Kılavuz

Bölüm I: Ağ Güvenliğinin Temel İlkeleri

Bu bölüm, modern ağ güvenliği pratiğinin üzerine inşa edildiği temel felsefi ve stratejik sütunları incelemektedir. Bu ilkeler, belirli teknolojilerden veya ürünlerden bağımsız olarak, bir organizasyonun dijital varlıklarını koruma çabalarına rehberlik eden evrensel kavramlardır.

1. Giriş: Güvenliğin Temel Taşları

Ağ güvenliği, yalnızca teknolojik bir zorluk değil, aynı zamanda stratejik bir zorunluluktur. Dijital altyapıların karmaşıklığı arttıkça ve tehditler daha sofistike hale geldikçe, savunma stratejilerini sağlam ve mantıksal temellere oturtmak hayati önem taşımaktadır. Bu temellerin en başında, bilgi güvenliğinin üç ana hedefi olan Gizlilik, Bütünlük ve Erişilebilirlik gelir. Bu üç ilke, "CIA Üçgeni" olarak bilinen ve tüm güvenlik politikalarının dengelenmesi gereken temel bir model oluşturur. Bu temel modelin üzerine, tek bir savunma hattının asla yeterli olmayacağı felsefesini benimseyen "Derinlemesine Savunma" stratejisi inşa edilir.

1.1. CIA Üçgeni: Gizlilik, Bütünlük ve Erişilebilirlik (Confidentiality, Integrity, Availability)

CIA Üçgeni, bilgi güvenliği için temel bir modeldir ve organizasyonların verileri yetkisiz erişime karşı koruma, doğruluğunu sağlama ve sistemlere güvenilir erişimi sürdürme çabalarına rehberlik eder. Ulusal Standartlar ve Teknoloji Enstitüsü (NIST) gibi kuruluşlar tarafından da benimsenen bu model, bir güvenlik altyapısının temel taşlarını oluşturur.

- **Gizlilik (Confidentiality):** Bu ilke, bilgilerin yalnızca yetkili kişiler, süreçler veya sistemler tarafından erişilebilir olmasını sağlamayı amaçlar. Temelde, verilerin "mahremiyetini" veya "gizliliğini" korumakla ilgilidir. Gizliliğin ihlali, hassas verilerin (finansal kayıtlar, kişisel bilgiler, ticari sırlar vb.) açığa çıkmasına, yasal cezalara ve itibar kaybına yol açabilir.
 - **Teknik Kontroller:** Gizliliği sağlamak için kullanılan en temel teknik kontrol **şifrelemedir**. AES (Advanced Encryption Standard) ve DES (Data Encryption Standard) gibi algoritmalar, veriyi okunamaz hale getirerek yetkisiz kişilerin eline geçse bile anlamsız olmasını sağlar. Sanal Özel Ağlar (VPN), verileri genel ağlar üzerinden taşırken şifreli tüneller oluşturarak iletişimin gizliliğini korur. Güvenlik duvarları (Firewalls) ve Erişim Kontrol Listeleri (ACL'ler), belirli IP adreslerinden veya portlardan gelen trafiği engelleyerek yetkisiz erişimi sınırlar.
- **Bütünlük (Integrity):** Bu ilke, verilerin yetkisiz veya uygunsuz bir şekilde değiştirilmesine veya yok edilmesine karşı korunmasını ve bilginin gerçekliğinin ve reddedilemezliğinin sağlanmasını hedefler. Veri bütünlüğü, bir bankanın işlem kayıtlarının veya bir hastanın tıbbi verilerinin doğruluğunun korunması gibi kritik senaryolarda hayati önem taşır.
 - **Teknik Kontroller:** Veri bütünlüğünü doğrulamak için **hash fonksiyonları** yaygın olarak kullanılır. MD5 (Message Digest 5) ve SHA (Secure Hash Algorithm) gibi algoritmalar, bir veriden benzersiz bir "parmak izi" (özet) oluşturur. Veri alındığında, alıcı aynı hash fonksiyonunu kullanarak yeni bir özet hesaplar ve bunu orijinal özetle karşılaştırır. Eğer özetler aynıysa, verinin yolda değiştirilmediği anlaşılır. **Dijital imzalar**, bir verinin hem bütünlüğünü hem de kaynağını doğrulamak için asimetrik kriptografi kullanır. Ayrıca, sistemlerdeki tüm değişiklikleri kaydeden denetim izleri (audit trails) ve olay günlükleri (event logs), yetkisiz değişikliklerin tespit edilmesine yardımcı olur.
- **Erişilebilirlik (Availability):** Bu ilke, bilgi ve sistemlerin yetkili kullanıcılar tarafından ihtiyaç duyulduğunda zamanında ve güvenilir bir şekilde erişilebilir olmasını garanti eder. Erişilebilirliğin kesintiye uğraması, iş operasyonlarını durdurabilir ve ciddi finansal kayıplara neden olabilir.
 - **Teknik Kontroller:** Erişilebilirliği sağlamak için **yedeklilik (redundancy)** temel bir stratejidir. Birden fazla sunucu, ağ bağlantısı veya güç kaynağı kullanmak, bir bileşen arızalandığında diğerinin devreye girmesini sağlar. **Yük dengeleyiciler (Load balancers)**, gelen istekleri birden fazla sunucuya dağıtarak tek bir sunucunun aşırı yüklenmesini ve hizmet veremez hale gelmesini önler. Dağıtılmış Hizmet Reddi (DDoS) saldırılarına karşı koruma sağlayan özel çözümler, ağ kaynaklarının kötü niyetli trafikle tüketilmesini engelleyerek meşru kullanıcıların erişimini sürdürmesini sağlar. Düzenli veri yedeklemeleri de bir felaket durumunda verilerin geri yüklenebilmesini sağlar.

Bu üç ilke arasında doğal bir denge ve bazen de bir çatışma durumu mevcuttur. Örneğin, çok katmanlı ve karmaşık şifreleme gibi aşırı sıkı gizlilik kontrolleri, sistemlerin yavaşlamasına veya erişimin zorlaşmasına



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

Derinlemesine Savunma (Defense in Depth - DiD), tek bir güvenlik kontrolünün veya katmanının başarısız olabileceği varsayımına dayanan çok katmanlı bir güvenlik felsefesidir. Amaç, bir saldırgan bir savunma hattını aşsa bile, sonraki katmanların saldırıyı yavaşlatmasını, tespit etmesini veya tamamen durdurmasını sağlamaktır. Bu strateji, askeri alandaki bir kalenin hendekler, surlar ve iç kaleler gibi birden çok savunma hattıyla korunması konseptinden ilham alır. Bilgi güvenliğinde ise bu, verinin merkezde olduğu bir soğan modeline benzetilebilir; her bir katman, çekirdekteki veriyi koruyan ek bir güvenlik tabakasıdır.

Derinlemesine Savunma, üç ana kontrol kategorisine ayrılır :

- **Fiziksel Kontroller:** Bu katman, BT altyapısına yetkisiz fiziksel erişimi engellemeye odaklanan ilk savunma hattıdır. Veri merkezlerini, sunucu odalarını ve ağ cihazlarını korur. Örnekler arasında kilitli kapılar, güvenlik görevlileri, biyometrik erişim sistemleri ve gözetim kameraları bulunur.
- **Teknik (Mantıksal) Kontroller:** Siber güvenliğin donanım ve yazılım tabanlı bileşenlerini içerir. Bu katman, ağ ve sistemleri siber tehditlere karşı korur. Yaygın teknik kontroller şunlardır :
 - **Ağ Güvenliği:** Güvenlik duvarları (Firewalls), Saldırı Önleme/Tespit Sistemleri (IPS/IDS), Web Uygulama Güvenlik Duvarları (WAF) ve ağ segmentasyonu.
 - **Uç Nokta Güvenliği:** Antivirüs yazılımları, Uç Nokta Tespiti ve Müdahalesi (EDR) çözümleri ve cihaz şifrelemesi.
 - **Veri Güvenliği:** Veri şifrelemesi (hem beklemedeyken hem de aktarım sırasında), Veri Kaybı Önleme (DLP) çözümleri.
 - **Kimlik ve Erişim Yönetimi (IAM):** Güçlü kimlik doğrulama yöntemleri (MFA gibi) ve rol tabanlı erişim kontrolü (RBAC).

- **İdari Kontroller:** Bir organizasyonun güvenlik duruşunu şekillendiren politika, prosedür ve standartları kapsar. Bu kontroller, insan faktörünü ve operasyonel süreçleri güvence altına alır. Örnekler arasında güvenlik farkındalık eğitimleri, olay müdahale planları, felaket kurtarma prosedürleri, işe alım süreçleri ve yasal uyumluluk (GDPR, HIPAA vb.) çerçeveleri yer alır.

Derinlemesine Savunma stratejisinin modern ağ mimarilerindeki yeri ve evrimi, güvenlik felsefesindeki önemli bir değişimi yansıtmaktadır. Geleneksel DiD modeli, "iç ağ" ve "dış ağ" arasında net bir ayrım olduğu ve iç ağın doğası gereği daha güvenilir olduğu varsayımına dayanır. Bu, "kale ve hendek" modelinin temelidir. Ancak, bulut bilişimin, uzaktan çalışmanın ve mobil cihazların (BYOD) yaygınlaşmasıyla birlikte bu net ayrım ortadan kalkmıştır. Artık güvenilir bir "iç ağ" kavramı geçerliliğini yitirmiş, ağ sınırı her yere yayılmıştır. Bu durum, DiD'nin temel varsayımlarından birini zayıflatmıştır. Bu değişime yanıt olarak, güvenlik paradigması ağ konumuna dayalı güvenden, kimliğe dayalı sürekli doğrulamaya kaymıştır. Bu yeni paradigma **Sıfır Güven (Zero Trust)** olarak adlandırılır. Sıfır Güven, DiD'nin modası geçmiş olduğu anlamına gelmez; aksine, onun mantıksal bir evrimidir. DiD'nin katmanlı yapısı hala geçerlidir, ancak Zero Trust bu katmanların her birinde "asla güvenme, her zaman doğrula" ilkesinin uygulanmasını zorunlu kılar. Dolayısıyla, Derinlemesine Savunma'dan Sıfır Güven'e geçiş, sadece bir teknoloji trendi değil, modern ağ mimarilerinin getirdiği zorunluluklara karşı geliştirilmiş doğal bir güvenlik cevabıdır.

2. Tehdit Ortamı ve Savunma Yaklaşımları

Etkili bir ağ güvenliği stratejisi, yalnızca savunma mekanizmalarını değil, aynı zamanda bu mekanizmaların karşı koyması gereken tehditlerin doğasını da anlamayı gerektirir. Bu bölümde, siber suçluların sistemlere sızmak için kullandığı yaygın yöntemler olan saldırı vektörleri incelenecek ve bu tehditlere karşı geliştirilen iki temel felsefi yaklaşım olan proaktif ve reaktif güvenlik stratejileri karşılaştırılacaktır.

2.1. Yaygın Saldırı Vektörleri ve Azaltma Yöntemleri

Saldırı vektörü, bir saldırganın bir ağa veya sisteme yetkisiz erişim sağlamak için kullandığı yol veya yöntemdir. Bu vektörleri anlamak, savunma stratejilerini doğru bir şekilde odaklamak için kritik öneme sahiptir.

- **Sosyal Mühendislik ve Kimlik Avı (Phishing):** Bu saldırılar, insan faktörünü hedef alır ve genellikle en başarılı vektörlerden biridir. Saldırganlar, meşru bir kurum (banka gibi) veya kişiden geliyormuş gibi görünen sahte e-postalar, SMS mesajları (smishing) veya sesli aramalar (vishing) kullanarak kurbanları kandırmaya çalışır. Amaç, kullanıcıların parolalar, kredi kartı bilgileri gibi hassas verileri ifşa etmelerini veya kötü amaçlı bir bağlantıya tıklayarak zararlı yazılım indirmelerini sağlamaktır.
 - **Azaltma Yöntemleri:** En etkili savunma, düzenli **güvenlik farkındalık eğitimleri** ile çalışanları bu tür saldırıları tanıma konusunda eğitmektir. Teknik düzeyde ise, **gelişmiş e-**



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

stratejisine sahip olmaktadır. "3-2-1 kuralı" (verilerinizin üç kopyasını iki farklı ortamda tutun ve bir kopyayı tesis dışında saklayın) bu konuda en iyi uygulamalardan biridir.

• **Web Uygulama Saldırıları:** Web siteleri ve uygulamaları, genellikle internete açık oldukları için popüler hedeflerdir. OWASP Top 10 listesi, en kritik web uygulama güvenlik risklerini özetler. Bunlar arasında **SQL Enjeksiyonu** (veritabanına kötü amaçlı sorgular gönderme), **Siteler Arası Komut Dosyası Çalıştırma (XSS)** (kullanıcının tarayıcısında kötü amaçlı betikler çalıştırma) ve **Sunucu Tarafı İstek Sahteciliği (SSRF)** (sunucunun kontrol dışı istekler yapmasını sağlama) gibi saldırılar bulunur.

◦ **Azaltma Yöntemleri:** Geliştirme aşamasında güvenli kodlama pratikleri ve kullanıcıdan gelen tüm girdilerin doğrulanması (input validation) esastır. Operasyonel olarak ise, **Web Uygulama Güvenlik Duvarları (WAF)**, bu tür saldırıları tespit edip engellemek için özel olarak tasarlanmıştır.

• **Kimlik Bilgisi Saldırıları:** Çalınan kullanıcı adları ve parolalar, saldırganlar için en değerli varlıklardan biridir. **Ele geçirilmiş kimlik bilgileri (compromised credentials)**, önceki veri sızıntılarından elde edilir ve **kimlik bilgisi doldurma (credential stuffing)** saldırılarında, bu çalınan listeler farklı web sitelerinde otomatik olarak denir.

◦ **Azaltma Yöntemleri:** **Çok Faktörlü Kimlik Doğrulama (MFA)**, parola çalınsa bile ek bir doğrulama adımı gerektirdiği için bu saldırılara karşı en etkili savunmadır. **Güçlü ve benzersiz parola politikaları** uygulamak ve anormal oturum açma davranışlarını (örneğin, beklenmedik bir coğrafi konumdan giriş denemesi) izlemek de kritik öneme sahiptir.

• **Ağ Zafiyetlerinin İstismarı:** Saldırganlar, ağ altyapısındaki zayıflıkları da hedef alır. **Yamalanmamış yazılımlar**, bilinen güvenlik açıklarını barındırır. **Yanlış yapılandırılmış güvenlik duvarları veya yönlendiriciler**, istenmeyen erişimlere kapı açabilir. **Ağ segmentasyonunun olmaması** ise bir saldırganın ağa sızdıktan sonra yanal olarak hareket ederek diğer sistemlere kolayca yayılmasına olanak tanır.

◦ **Azaltma Yöntemleri:** Düzenli ve otomatikleştirilmiş bir **yama yönetimi programı** uygulamak, bilinen zafiyetleri kapatır. **Saldırı Tespit/Önleme Sistemleri (IDS/IPS)** ve doğru yapılandırılmış güvenlik duvarları, şüpheli ağ trafiğini izler ve engeller. **Ağ segmentasyonu**, bir ihlalin etkisini sınırlayarak yayılmasını zorlaştırır.

Aşağıdaki tablo, bu yaygın saldırı vektörlerini, taşıdıkları riskleri ve bunlara karşı alınabilecek temel önleme yöntemlerini özetlemektedir. Bu tablo, bir güvenlik uzmanının belirli bir tehdide karşı hangi kontrollerin uygulanması gerektiğini hızla belirlemesine olanak tanıyarak pratik bir başvuru kaynağı sunar.

Saldırı Vektörü	Risk	Önleme Yöntemi
Ele Geçirilmiş Kimlik Bilgileri	Yetkisiz erişim, ayrıcalık yükseltme	MFA kullanın, anormal oturum açma davranışlarını izleyin
Kimlik Bilgisi Doldurma	Hesap ele geçirme	Benzersiz parolalar talep edin, bot trafiğini engelleyin
Kimlik Avı (Phishing)	Kimlik bilgisi hırsızlığı, kötü amaçlı yazılım bulaşması	Kullanıcıları eğitin, e-postaları tarayın, güvenli e-posta ağ geçitleri kullanın
Kötü Amaçlı Yazılım (Malware)	Sistem ele geçirme, veri kaybı	Sistemleri yamalayın, ağ segmentasyonu yapın, antivirüs ve EDR kullanın
Fidye Yazılımı (Ransomware)	Verilerin kilitlenmesi, iş kesintisi	Verileri düzenli olarak yedekleyin, personeli eğitin, erken tespit sistemleri kullanın
Sıfır Gün Açıkları (Zero-Day)	Bilinmeyen zafiyetlerin istismarı	EDR kullanın, tehdit istihbaratı akışlarını takip edin
Yanlış Yapılandırma	Hassas sistemlerin açığa çıkması	Yapılandırmaları düzenli olarak denetleyin, IaC kullanın
DDoS Saldırıları	Hizmet kesintisi	WAF, CDN ve yük dengeleyiciler kullanın
Enjeksiyon (SQLi, XSS) / MitM	Veri hırsızlığı, sistem manipülasyonu	Girdileri doğrulayın, veriyi aktarım sırasında şifreleyin (HTTPS, VPN)



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

mevcut zayıflıkları belirleyerek riskleri önceliklendirmek.

- **Güvenlik Açığı Taraması (Vulnerability Scanning):** Ağdaki ve sistemlerdeki bilinen güvenlik açıklarını otomatik araçlarla tarayarak saldırganlardan önce tespit etme.
- **Tehdit Avcılığı (Threat Hunting):** Geleneksel güvenlik araçlarından (antivirüs, güvenlik duvarı vb.) kaçmayı başarmış olabilecek gizli tehditleri, insan uzmanlığı ve gelişmiş araçlar kullanarak aktif olarak arama süreci.
- **Güvenlik Farkındalık Eğitimleri:** Çalışanları en son siber tehditler ve en iyi güvenlik uygulamaları konusunda bilgilendirerek insan faktöründen kaynaklanan riskleri azaltma.
- **Reaktif Güvenlik:** Bu yaklaşım, bir güvenlik olayı veya ihlali meydana geldikten sonra gerçekleştirilen eylemleri içerir. Amacı, hasarı en aza indirmek, sistemi normal işleyişine döndürmek ve gelecekte benzer olayların tekrarlanmasını önlemektir. Reaktif faaliyetler şunları içerir:
 - **Olay Müdahalesi (Incident Response):** Bir ihlale yanıt verme, etkisini sınırlama ve sistemi kurtarma süreci.
 - **Yama Yönetimi (Patch Management):** Bir saldırıda istismar edilen bir güvenlik açığını kapatmak için acil yazılım güncellemeleri uygulama.
 - **Felaket Kurtarma (Disaster Recovery):** Büyük bir kesintinin ardından sistemleri ve verileri yedeklerden geri yükleme.

Proaktif ve reaktif güvenlik, birbirine zıt kavramlar olarak değil, birbirini besleyen simbiyotik bir döngünün parçaları olarak görülmelidir. Güçlü bir reaktif süreç, proaktif savunmayı doğrudan güçlendirir. Bir saldırı meydana geldiğinde (reaktif bir durum), devreye giren **Dijital Adli Bilişim ve Olay Müdahalesi (Digital Forensics and Incident Response - DFIR)** süreci, bu döngünün en kritik halkasıdır. DFIR, bir siber saldırının nasıl gerçekleştiğini, hangi sistemlerin etkilendiğini ve saldırganın hangi yöntemleri kullandığını derinlemesine analiz eder. Bu analizden elde edilen somut bulgular ve kanıtlar, paha biçilmez bir tehdit istihbaratına dönüşür. Bu istihbarat, gelecekteki benzer saldırıları önlemek için proaktif kontrollerin geliştirilmesine doğrudan girdi sağlar. Örneğin, DFIR analizi sonucunda belirli bir yazılımdaki yamalanmamış bir zafiyetin istismar edildiği ortaya çıkarsa, bu bilgi proaktif güvenlik açığı tarama programını bu zafiyeti öncelikli olarak tarayacak şekilde yönlendirir. Benzer şekilde, başarılı bir kimlik avı saldırısının analizi, proaktif kullanıcı eğitimlerinin içeriğini bu yeni tekniği kapsayacak şekilde günceller. Dolayısıyla, her reaktif olay, proaktif savunma duruşunu güçlendiren ve olgunlaştıran bir öğrenme fırsatı sunar.

Dijital Adli Bilişim ve Olay Müdahalesi (DFIR) Süreci

DFIR, bir güvenlik olayına yapılandırılmış bir şekilde müdahale etme ve olaydan adli kanıtlar toplama disiplini. Genellikle aşağıdaki aşamalardan oluşur:

1. **Hazırlık (Preparation):** Olaylara hazırlıklı olmak için gerekli araçların, süreçlerin ve ekiplerin önceden oluşturulması. Bu aşama, bir olay müdahale planı oluşturmayı, ekibi eğitmeyi ve gerekli adli bilişim ve izleme araçlarını kurmayı içerir.
2. **Tespit ve Analiz (Identification & Analysis):** Bir olayın meydana geldiğini belirleme ve kapsamını, kaynağını ve etkisini analiz etme. Bu, SIEM uyarıları, anormal ağ trafiği veya kullanıcı raporları gibi çeşitli kaynaklardan gelebilir.
3. **Sınırlama (Containment):** Saldırının yayılmasını ve daha fazla hasar vermesini önlemek için olayın etkisini sınırlama. Bu, etkilenen sistemleri ağdan izole etmeyi veya belirli hizmetleri geçici olarak durdurmayı içerebilir.
4. **Yok Etme (Eradiation):** Saldırının temel nedenini ve saldırgana ait tüm izleri (kötü amaçlı yazılım, arka kapılar vb.) sistemlerden tamamen temizleme.
5. **Kurtarma (Recovery):** Etkilenen sistemleri ve verileri güvenli bir duruma geri yükleme ve normal operasyonlara dönme. Bu, sistemlerin yedeklerden geri yüklenmesini ve güvenliklerinin doğrulanmasını içerir.
6. **Olay Sonrası Faaliyetler (Post-Incident Activity / Lessons Learned):** Olayın nedenlerini, müdahale sürecinin etkinliğini ve gelecekte benzer olayların nasıl önlenebileceğini analiz etme. Bu aşamadan elde edilen bulgular, proaktif güvenlik kontrollerini ve hazırlık aşamasını iyileştirmek için kullanılır.

Bu süreçte, özellikle yasal süreçler için kanıtların bütünlüğünün korunması hayati önem taşır. Toplanan tüm dijital kanıtlar, değiştirilmediğini ve kurcalanmadığını garanti edecek şekilde adli prosedürlere uygun olarak toplanmalı ve saklanmalıdır.

Bölüm II: Güvenli İletişim ve Kriptografi

Ağ güvenliğinin temel amacı, verilerin bir noktadan diğerine taşınırken yetkisiz gözlerden korunmasını ve değiştirilmeden hedefe ulaşmasını sağlamaktır. Bu amacın teknolojik temelini kriptografi, yani şifreleme bilimi oluşturur. Bu bölümde, verileri korumak için kullanılan temel kriptografik yöntemler, bu



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

3.1. Simetrik ve Asimetrik Şifreleme Karşılaştırması

Kriptografide kullanılan iki temel şifreleme paradigması vardır: simetrik ve asimetrik şifreleme. Her birinin kendine özgü avantajları, dezavantajları ve kullanım alanları bulunur.

• **Simetrik Şifreleme:** Bu yöntemde, hem şifreleme hem de deşifreleme işlemleri için **tek bir gizli anahtar** kullanılır. İletişimdeki her iki tarafın da aynı anahtara sahip olması gerekir.

◦ **Avantajları:** Simetrik algoritmalar, asimetrik olanlara göre çok daha **hızlıdır** ve daha az işlem gücü gerektirir. Bu nedenle, büyük miktarda verinin (örneğin, bir dosya transferi veya video akışı) şifrlenmesi için idealdirler.

◦ **Dezavantajları:** En büyük zorluğu **anahtar dağıtımıdır**. Gizli anahtarın taraflar arasında güvenli bir şekilde paylaşılması gerekir. Eğer anahtar güvensiz bir kanal üzerinden gönderilirse, bir saldırgan tarafından ele geçirilebilir ve tüm iletişim tehlikeye girer.

◦ **Popüler Algoritmalar:**

■ **AES (Advanced Encryption Standard):** Günümüzün endüstri standardıdır. 128, 192 veya 256-bit anahtar uzunluklarını destekler ve son derece güvenli kabul edilir.

■ **3DES (Triple DES):** Orijinal DES algoritmasının üç kez art arda uygulanmasıyla oluşturulmuştur. AES'e göre yavaştır ancak hala bazı finansal uygulamalarda ve eski sistemlerde kullanılmaktadır.

■ **DES (Data Encryption Standard):** 56-bit anahtar uzunluğu nedeniyle günümüzde güvensiz kabul edilmektedir ve kırılmıştır.

■ Diğer algoritmalar arasında **Blowfish**, **TwoFish** ve **RC4** bulunur.

• **Asimetrik Şifreleme (Açık Anahtar Kriptografisi):** Bu yöntem, matematiksel olarak birbirine bağlı bir **açık anahtar** ve bir **özel anahtar** çifti kullanır.

◦ **Çalışma Prensipleri:** Açık anahtar herkesle güvenli bir şekilde paylaşılabilir. Bir veriyi şifrelemek için alıcının açık anahtarı kullanılır. Bu şifrelenmiş veri, **sadece alıcının sahip olduğu ilgili özel anahtar** ile çözülebilir.

◦ **Avantajları:** Simetrik şifrelemenin anahtar dağıtım sorununu çözer. Anahtarı güvenli bir şekilde paylaşma ihtiyacı yoktur, çünkü açık anahtarın ele geçirilmesi bir güvenlik riski oluşturmaz. Ayrıca dijital imzalar ve kimlik doğrulama gibi ek güvenlik işlevleri sağlar.

◦ **Dezavantajları:** Simetrik şifrelemeye göre önemli ölçüde **yavaştır** ve çok daha fazla işlem gücü gerektirir. Bu nedenle büyük veri bloklarını doğrudan şifrelemek için verimsizdir.

◦ **Popüler Algoritmalar:**

■ **RSA (Rivest-Shamir-Adleman):** En yaygın kullanılan asimetrik algoritmadır. Güvenliği, büyük sayıları çarpanlarına ayırmanın matematiksel zorluğuna dayanır.

■ **Diffie-Hellman (DH):** Güvenli olmayan bir kanal üzerinden iki tarafın ortak bir gizli anahtar üzerinde anlaşmasını sağlayan bir anahtar değişim protokolüdür. Doğrudan veri şifreleme için kullanılmaz.

■ Diğerleri arasında **El Gamal** ve **Eliptik Eğri Kriptografisi (ECC)** bulunur.

• **Hibrit Yaklaşım:** Pratikte, modern güvenlik protokollerinin çoğu (örneğin, HTTPS'in temelini oluşturan TLS/SSL) bu iki yöntemin en iyi yönlerini birleştiren hibrit bir yaklaşım kullanır. İletişim başladığında, taraflar asimetrik şifreleme (örneğin, RSA veya DH) kullanarak güvenli bir şekilde tek kullanımlık bir **simetrik oturum anahtarı (session key)** oluşturur ve paylaşır. Bu yavaş ve işlemci yoğun olan adım tamamlandıktan sonra, asıl veri aktarımının tamamı bu hızlı simetrik oturum anahtarı (örneğin, AES) ile şifrelenir. Bu, hem asimetrik şifrelemenin güvenli anahtar dağıtım avantajını hem de simetrik şifrelemenin yüksek performansını bir araya getirir.

Aşağıdaki tablo, iki şifreleme türü arasındaki temel farkları özetlemektedir:

Özellik	Simetrik Şifreleme	Asimetrik Şifreleme
Anahtar Sayısı	Tek bir gizli anahtar	Bir açık ve bir özel anahtar çifti
Hız	Hızlı	Yavaş
Anahtar Dağıtımı	Zor ve riskli	Kolay ve güvenli
Temel Avantaj	Yüksek performans	Güvenli anahtar yönetimi, dijital imza
Temel Dezavantaj	Anahtar dağıtım sorunu	Düşük performans
Örnek Algoritmalar	AES, 3DES, Blowfish	RSA, Diffie-Hellman, ECC

3.2. Hash Fonksiyonları ve Veri Bütünlüğü

Hash fonksiyonları (özetleme fonksiyonları), kriptografide veri bütünlüğünü sağlamak için kullanılan temel araçlardır. Değişken uzunluktaki bir girdiyi (mesaj, dosya, parola vb.) alıp, onu sabit uzunlukta,



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

• **Çakışmaya Dayanıklılık (Collision Resistance):** İki farklı girdinin aynı hash çıktısını üretmesi (çakışma) olasılığı son derece düşüktür. Güçlü bir hash fonksiyonunda çakışma bulmak hesaplama açısından imkansız olmalıdır.

• **Yaygın Algoritmalar ve Karşılaştırma:**

• **MD5 (Message Digest 5):** 128-bitlik bir hash değeri üretir. Hızlı olması nedeniyle geçmişte yaygın olarak kullanılmıştır. Ancak, ciddi güvenlik zafiyetleri olduğu ve çakışma saldırılarına karşı savunmasız olduğu kanıtlanmıştır. Bu nedenle, güvenlik gerektiren uygulamalarda artık kullanılmamalıdır.

• **SHA-256 (Secure Hash Algorithm 256-bit):** SHA-2 ailesinin bir üyesidir ve 256-bitlik bir hash değeri üretir. Daha uzun hash çıktısı sayesinde çakışma saldırılarına karşı çok daha dirençlidir ve günümüzün güvenlik standardı olarak kabul edilir. Bitcoin gibi kripto para birimlerinde ve dijital sertifikalarda yaygın olarak kullanılır. İlginç bir şekilde, modern işlemci mimarilerindeki donanım hızlandırmaları sayesinde SHA-256, bazı durumlarda MD5'ten daha hızlı çalışabilmektedir.

• **Doğum Günü Saldırısı (Birthday Attack):** Bu saldırı, bir hash fonksiyonunun çakışma direncini kırmaya yönelik bir kriptoanaliz tekniğidir. Adını, "doğum günü paradoksu" olarak bilinen olasılık probleminden alır: 23 kişilik bir grupta, iki kişinin aynı doğum gününü paylaşma olasılığının %50'den fazla olması. Bu mantık hash fonksiyonlarına uygulandığında, belirli bir hash değerini üretecek bir girdi bulmak (ön-imaj saldırısı) çok zorken, aynı hash değerini üreten *herhangi* iki farklı girdi bulmak (çakışma) çok daha kolaydır.

• **Teknik İşleyiş:** n-bitlik bir hash fonksiyonunun güvenlik seviyesi normalde 2^n olarak kabul edilir. Ancak doğum günü saldırısı sayesinde, bir çakışma bulmak için gereken ortalama deneme sayısı sadece $2^{n/2}$ 'dir. Örneğin, 128-bitlik MD5 için bir çakışma bulmak, 2^{128} yerine yaklaşık 2^{64} deneme gerektirir ki bu, modern hesaplama gücüyle ulaşılabilir bir hedeftir. Bu saldırı, özellikle dijital imza sistemleri için tehlikelidir. Bir saldırgan, meşru bir belge ve kötü amaçlı bir belge olmak üzere iki belge hazırlayabilir ve her ikisinden de aynı hash değerini üreten küçük, anlamsız varyasyonlar oluşturabilir. Kurban meşru belgeyi imzaladığında, saldırgan bu imzayı alıp kötü amaçlı belgeye ekleyebilir, çünkü her iki belgenin de hash değeri aynıdır.

4. Dijital Kimlik ve İnkâr Edememe

Güvenli iletişimde, sadece verinin gizliliğini ve bütünlüğünü sağlamak yeterli değildir; aynı zamanda iletişimdeki tarafların kimliklerinden emin olmak ve gerçekleştirdikleri eylemleri daha sonra inkâr edememelerini sağlamak da gerekir. Bu, Açık Anahtar Altyapısı (PKI) ve dijital imzalar aracılığıyla gerçekleştirilir.

4.1. Açık Anahtar Altyapısı (PKI) ve Dijital Sertifikalar

Açık Anahtar Altyapısı (PKI), dijital sertifikaların oluşturulması, dağıtılması, yönetilmesi, saklanması ve iptal edilmesi için gerekli olan donanım, yazılım, politikalar, standartlar ve prosedürler bütünüdür. PKI'nin temel amacı, bir açık anahtarın belirli bir kimliğe (bir kişi, sunucu veya organizasyon) ait olduğunu güvenilir bir üçüncü taraf aracılığıyla doğrulamaktır.

• **Temel Bileşenler:**

- **Sertifika Otoritesi (CA - Certificate Authority):** Dijital sertifikaları yayınlayan ve imzalayan güvenilir kuruluştur. CA, sertifika sahibinin kimliğini doğrulamaktan sorumludur.
- **Kayıt Otoritesi (RA - Registration Authority):** CA adına kimlik doğrulama işlemlerini gerçekleştiren yetkili birimdir.
- **Dijital Sertifika (X.509 Standardı):** Bir açık anahtarı, sahibinin kimlik bilgileri (örneğin, alan adı, organizasyon adı) ve diğer meta verilerle (geçerlilik süresi, seri numarası vb.) birleştiren ve bir CA tarafından dijital olarak imzalanan elektronik bir belgedir. Web sitelerinde HTTPS'i etkinleştirmek için kullanılan SSL/TLS sertifikaları, en yaygın dijital sertifika türüdür.

4.2. Dijital İmzaların Çalışma Prensibi

Dijital imza, el yazısıyla atılan ıslak imzanın dijital eşdeğeridir ancak çok daha güçlü güvenlik garantileri sunar. Bir belgenin veya mesajın bütünlüğünü, göndericisinin kimliğini ve göndericinin bu eylemi inkâr edemeyeceğini kriptografik olarak kanıtlar.



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

anahtarını kullanarak dijital imzanın şifresini çözer. Bu işlem sonucunda, göndericinin orijinal olarak hesapladığı hash özeti elde edilir (Hash 1).

3. **Yeniden Özetleme:** Alıcı, aldığı orijinal belgenin hash'ini, göndericinin kullandığı aynı hash algoritmasıyla kendisi de hesaplar (Hash 2).

4. **Karşılaştırma:** Alıcı, deşifreleme yoluyla elde ettiği Hash 1 ile kendisinin hesapladığı Hash 2'yi karşılaştırır.

• Sağlanan Güvenlik Garantileri:

- **Bütünlük (Integrity):** Eğer iki hash değeri (Hash 1 ve Hash 2) birbiriyle eşleşirse, bu, belgenin alıcıya ulaşana kadar yolda hiçbir değişikliğe uğramadığını kanıtlar. Belgede tek bir bit bile değişseydi, hesaplanan hash değeri tamamen farklı olurdu.
- **Kimlik Doğrulama (Authentication):** İmza, göndericinin açık anahtarı ile başarılı bir şekilde deşifre edilebildiği için, bu imzanın yalnızca o açık anahtarın karşılığı olan özel anahtarın sahibi tarafından oluşturulabileceği matematiksel olarak kanıtlanmış olur. Bu, mesajın gerçekten iddia edilen göndericiden geldiğini doğrular.
- **İnkâr Edememe (Non-repudiation):** Gönderici, mesajı gönderdiğini veya belgeyi imzaladığını daha sonra inkâr edemez. Çünkü dijital imzayı oluşturabilecek tek kriptografik anahtar olan özel anahtar, sadece kendi kontrolündedir. Bu özellik, dijital işlemlere yasal geçerlilik kazandıran en önemli unsurlardan biridir.

Bölüm III: Ağ Savunma Teknolojileri ve Mimarileri

Ağ güvenliğinin teorik temelleri anlaşıldıktan sonra, bu ilkeleri pratikte uygulayan teknolojik çözümlerin ve mimari tasarımların incelenmesi gerekmektedir. Bu bölüm, modern ağları siber tehditlere karşı korumak için kullanılan donanım ve yazılım tabanlı savunma mekanizmalarını, çalışma prensiplerini ve birbirleriyle olan ilişkilerini detaylı bir şekilde ele almaktadır.

5. Ağ Trafikini Filtreleme ve Kontrol Etme

Ağ güvenliğinin en temel işlevi, meşru ve kötü niyetli ağ trafiğini birbirinden ayırmak ve yalnızca güvenilir iletişime izin vermektir. Bu işlevi yerine getiren temel teknolojiler güvenlik duvarları ve proxy sunucularıdır.

5.1. Güvenlik Duvarı (Firewall) Mimarileri

Güvenlik duvarları, bir ağın giriş ve çıkış noktalarında konumlandırılarak, önceden tanımlanmış bir dizi güvenlik kuralına göre ağ trafiğini denetleyen, filtreleyen ve kontrol eden donanım veya yazılım tabanlı sistemlerdir. Bir ağın ilk savunma hattı olarak kabul edilirler.

Güvenlik duvarlarının evrimi, siber saldırıların karmaşıklığındaki artışa doğrudan bir yanıt niteliğindedir. İlk saldırılar, belirli portlara yönelik basit taramalar ve erişim denemeleri gibi ağ katmanı odaklıydı. Bu tehditlere karşı, sadece IP adresi ve port numarası gibi temel bilgilere bakan **Paket Filtreleme (Packet Filtering)** güvenlik duvarları yeterliydi. Ancak saldırganlar, izin verilen ve yaygın olarak kullanılan portlar (örneğin, web trafiği için port 80) üzerinden daha sofistike saldırılar düzenlemeye başladılar. Bu duruma yanıt olarak, bir bağlantının meşru bir oturumun parçası olup olmadığını takip edebilen **Durum Tabanlı (Stateful Inspection)** güvenlik duvarları geliştirildi. Son olarak, saldırganlar meşru bağlantıların içine gizlenmiş uygulama katmanı saldırılarını (örneğin, bir web sunucusuna yönelik SQL enjeksiyonu) kullanmaya başladığında, geleneksel güvenlik duvarları bu trafiğin içeriğini anlayamadığı için yetersiz kaldı. Bu güvenlik boşluğunu doldurmak için, trafiğin sadece başlığını değil, içeriğini de derinlemesine inceleyebilen ve belirli uygulamaları tanıyabilen **Yeni Nesil Güvenlik Duvarları (NGFW)** ortaya çıktı. Bu evrim, güvenlik savaşının ağ katmanından uygulama katmanına taşınmasının kaçınılmaz bir sonucudur.

- **Paket Filtreleme Güvenlik Duvarı (Packet Filtering Firewall):** En eski ve en temel güvenlik duvarı türüdür. OSI modelinin 3. (Ağ) ve 4. (Taşıma) katmanlarında çalışır. Gelen ve giden paketlerin başlıklarındaki kaynak/hedef IP adresi, port numarası ve protokol tipi gibi bilgilere bakarak, önceden tanımlanmış erişim kontrol listelerine (ACL) göre paketi engeller veya geçişine izin verir. Çok hızlıdır ve ağ performansına etkisi minimum düzeydedir, ancak bağlantının genel bağlamını veya paketlerin içeriğini analiz etmez.

- **Durum Tabanlı Güvenlik Duvarı (Stateful Inspection Firewall):** Paket filtreleme güvenlik duvarlarının yeteneklerini, bir "durum tablosu" (state table) tutarak genişletir. Bu tablo, ağ üzerinden geçen tüm aktif bağlantıların (örneğin, TCP el sıkışmaları) kaydını tutar. Bu sayede, gelen bir paketin mevcut ve meşru bir bağlantının parçası olup olmadığını anlayabilir. Örneğin,



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

değil, aynı zamanda veri yüklerini (payload) de inceleyerek kötü amaçlı yazılım, virüs veya saldırı imzaları arar.

- **Entegre Saldırı Önleme Sistemi (IPS):** Bilinen saldırı kalıplarını tespit edip aktif olarak engelleyebilen bir IPS modülü içerir.
- **Ek Özellikler:** Genellikle SSL/TLS şifreli trafik denetimi, kullanıcı kimliği entegrasyonu (Active Directory gibi) ve gelişmiş tehdit istihbaratı beslemeleri gibi ek yeteneklere sahiptir.

5.2. Web Uygulama Güvenlik Duvarı (WAF)

Web Uygulama Güvenlik Duvarı (WAF), özellikle web uygulamalarını hedef alan saldırılara karşı koruma sağlamak için tasarlanmış özel bir güvenlik duvarı türüdür. OSI modelinin 7. katmanında (Uygulama Katmanı) çalışır ve HTTP/HTTPS trafiğini derinlemesine analiz eder.

- **Koruma Sağladığı Saldırıları:** WAF'lar, OWASP Top 10 listesinde yer alan en kritik web uygulama güvenlik risklerine karşı etkilidir. Bunlar arasında :
 - **SQL Enjeksiyonu (SQL Injection):** Veritabanı sorgularını manipüle etme girişimleri.
 - **Siteler Arası Komut Dosyası Çalıştırma (XSS - Cross-Site Scripting):** Kullanıcıların tarayıcılarına kötü amaçlı betikler enjekte etme.
 - **Bozuk Erişim Kontrolü (Broken Access Control):** Yetkisiz olarak sayfalara veya işlemlere erişim denemeleri.
 - **Sunucu Tarafı İstek Sahteciliği (SSRF - Server-Side Request Forgery).**
- **WAF ve NGFW Farkı:** Her ikisi de uygulama katmanında çalışabilir de, aralarında önemli farklar vardır. NGFW, genel ağ güvenliği için geniş bir yelpazede koruma sunarken, WAF yalnızca HTTP/HTTPS protokollerine odaklanır ve bu protokoller üzerindeki saldırı teknikleri konusunda çok daha derinlemesine uzmanlığa ve kural setlerine sahiptir. Birçok modern güvenlik mimarisinde, genel ağ koruması için bir NGFW ve web sunucularının önünde ek bir koruma katmanı olarak bir WAF birlikte kullanılır.

5.3. Proxy Sunucuları: Forward ve Reverse Proxy

Proxy sunucusu, bir istemci ile bir sunucu arasında aracı olarak hareket eden bir sunucudur. İsteği yapan istemci adına sunucuyla iletişim kurar ve sunucudan gelen yanıtı istemciye iletir. İki temel proxy türü vardır :

- **İleri Yönlü Proxy (Forward Proxy):** Bu proxy, **dahili ağdaki istemciler adına** hareket eder. Bir istemci internetteki bir sunucuya erişmek istediğinde, isteği önce forward proxy'ye gönderir. Proxy, bu isteği kendi IP adresiyle internetteki sunucuya iletir. Bu mimarinin temel kullanım amaçları şunlardır :
 - **Anonimlik ve IP Gizleme:** Dış sunucu, isteğin orijinal istemciden değil, proxy'den geldiğini görür.
 - **İçerik Filtreleme:** Kurumlar, çalışanların belirli web sitelerine (örneğin, sosyal medya) erişimini engellemek için forward proxy kullanabilir.
 - **Önbelleğe Alma (Caching):** Sık erişilen web içeriğini önbelleğe alarak bant genişliği kullanımını azaltır ve erişimi hızlandırır.
- **Ters Yönlü Proxy (Reverse Proxy):** Bu proxy, **arka plandaki sunucular adına** hareket eder. İnternette gelen bir istemci isteği, doğrudan web sunucusuna değil, önce reverse proxy'ye ulaşır. Proxy, isteği uygun arka uç sunucusuna yönlendirir ve sunucudan gelen yanıtı alıp istemciye iletir. Bu mimarinin temel kullanım amaçları şunlardır :
 - **Yük Dengeleme (Load Balancing):** Gelen istekleri birden fazla arka uç sunucusuna dağıtarak tek bir sunucunun aşırı yüklenmesini önler ve yüksek erişilebilirlik sağlar.
 - **SSL Sonlandırma (SSL Termination):** Gelen HTTPS trafiğinin şifresini çözer ve arka uç sunucularına şifresiz (HTTP) olarak iletir. Bu, şifreleme/deşifreleme yükünü web sunucularından alarak performanslarını artırır.
 - **Güvenlik ve Sunucu Gizleme:** Arka uç sunucularının IP adreslerini ve mimarisini internetten gizleyerek doğrudan saldırılara karşı bir koruma katmanı oluşturur.

6. Tehdit Tespiti ve Önleme Sistemleri

Güvenlik duvarları ve proxy'ler, önceden tanımlanmış kurallara dayalı olarak trafiği filtrelerken, daha dinamik ve sofistike tehditleri tespit etmek için ek sistemlere ihtiyaç duyulur. Bu sistemler, ağdaki



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

aktivite tespit ettiğinde, bir uyarı (alert) oluşturarak güvenlik yöneticisini bilgilendirir. Ancak, trafiğe aktif olarak müdahale etmez; yani saldırıyı **durdurmaz**, sadece **tespit eder** ve raporlar. Bu nedenle "out-of-band" bir çözüm olarak kabul edilir.

• **IPS (Intrusion Prevention System - Saldırı Önleme Sistemi):** Bir IPS, ağ trafiği akışının doğrudan üzerine (in-line) yerleştirilir. Gelen ve giden tüm paketleri analiz eder. Kötü niyetli bir aktivite tespit ettiğinde, sadece uyarı oluşturmakla kalmaz, aynı zamanda bu trafiği aktif olarak **engeller** veya bağlantıyı sıfırlar. Bu proaktif müdahale yeteneği, onu IDS'den ayırır.

Bu sistemler, tehditleri tespit etmek için iki ana yöntem kullanır:

• **İmza Tabanlı Tespit (Signature-based Detection):** Bu yöntem, bilinen saldırıların, kötü amaçlı yazılımların veya güvenlik açıklarının benzersiz kalıplarını (imzalarını) içeren bir veritabanı kullanır. Ağ trafiğini bu imzalarla karşılaştırır ve bir eşleşme bulduğunda alarm verir. Bilinen tehditleri tespit etmede çok etkilidir, ancak daha önce görülmemiş, yani imzası olmayan **sıfır gün (zero-day)** saldırılarına karşı kördür.

• **Anomali Tabanlı Tespit (Anomaly-based Detection):** Bu yöntem, ağın veya sistemin "normal" davranış profilini oluşturmak için makine öğrenimi ve istatistiksel analiz kullanır. Bu normal davranış taban çizgisinden (baseline) önemli sapmalar gösteren aktiviteleri potansiyel tehdit olarak işaretler. Yeni ve bilinmeyen saldırıları tespit etme potansiyeline sahiptir. Ancak en büyük dezavantajı, meşru ancak olağandışı aktiviteleri de tehdit olarak işaretleyebilmesi, yani **yanlış pozitif (false positive)** oranının yüksek olabilmesidir.

6.2. SIEM ve SOAR ile Güvenlik Operasyonları Orkestrasyonu

Modern kurumsal ağlar, güvenlik duvarları, sunucular, uç noktalar ve uygulamalar gibi sayısız kaynaktan devasa miktarda log ve olay verisi üretir. Bu verileri manuel olarak analiz etmek imkansızdır. SIEM ve SOAR platformları, bu veri selini yönetmek ve güvenlik operasyonlarını otomatikleştirmek için kullanılır.

• **SIEM (Security Information and Event Management):** Bir SIEM platformunun temel işlevi, bir organizasyonun tüm BT altyapısındaki çeşitli kaynaklardan log ve olay verilerini **toplamak**, bunları ortak bir formata **normalize etmek** ve merkezi bir konumda depolamaktır. Ardından, önceden tanımlanmış **korelasyon kurallarını** kullanarak bu verileri gerçek zamanlı olarak analiz eder. Birbiriyle ilişkili görünen şüpheli olayları (örneğin, bir kullanıcı hesabında 10 dakika içinde 100 başarısız oturum açma denemesi ve ardından başarılı bir giriş) tespit ederek bir güvenlik olayı olarak işaretler ve güvenlik ekibine bir uyarı gönderir. SIEM, temel olarak bir "güvenlik alarm sistemi" görevi görür.

• **SOAR (Security Orchestration, Automation, and Response):** SOAR platformları, SIEM ve diğer güvenlik araçlarından gelen uyarıları alarak bir sonraki adımı atar. Güvenlik operasyonları merkezlerinin (SOC) tekrarlayan ve zaman alıcı görevlerini otomatikleştirmek için tasarlanmıştır. SOAR, "**playbook**" adı verilen önceden tanımlanmış iş akışlarını kullanarak uyarılara otomatik olarak yanıt verir.

◦ **Örnek Playbook Akışı (Phishing Saldırısı):**

1. Bir kullanıcı, şüpheli bir e-postayı raporlar.
2. SOAR platformu, bu raporu otomatik olarak alır.
3. Playbook başlar: E-postadaki URL'leri, IP adreslerini ve ekleri otomatik olarak ayrıştırır.
4. URL'leri ve IP adreslerini tehdit istihbaratı servislerinde kontrol eder.
5. E-posta ekini bir sanal alan (sandbox) ortamında güvenli bir şekilde çalıştırarak davranışını analiz eder.
6. Eğer tehdit doğrulanırsa, SOAR otomatik olarak şu eylemleri tetikleyebilir: ilgili IP adresini güvenlik duvarında engelleme, benzer e-postaları tüm kullanıcılardan silme, etkilenen kullanıcının parolasını sıfırlama ve bir olay müdahale bileti oluşturma.

SIEM ve SOAR entegrasyonu, modern bir SOC için bir güç çarpanı görevi görür. SIEM, "ne olduğu" sorusuna yanıt verirken, SOAR "ne yapılması gerektiği" sorusunu otomatik olarak yanıtlar. Bu entegrasyon, analistlerin sürekli uyarı akışı altında ezilmesini (alert fatigue) önler, tehditlere müdahale süresini (MTTD/MTTR) dakikalara, hatta saniyelere indirir ve insan hatası riskini önemli ölçüde azaltır. Bu, güvenlik operasyonlarını reaktif bir analiz modelinden, proaktif ve otomatik bir tehdit avlama ve yok etme modeline dönüştüren stratejik bir adımdır.

7. Güvenli Ağ Erişimi ve Segmentasyonu

Bir ağın güvenliği, yalnızca dış tehditleri engellemekle kalmaz, aynı zamanda ağa bağlanan cihazların güvenilirliğini sağlamak ve ağ içindeki trafiği mantıksal olarak ayırmakla da ilgilidir. Bu bölümde, ağa



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

cihazda güncel bir antivirüs yazılımının olup olmadığını, işletim sisteminin en son yamalarına sahip olup olmadığını veya belirli bir yazılımın yüklü olup olmadığını kontrol edebilir. Uyumlu olmayan cihazlar ya ağa alınmaz, ya da sınırlı erişime sahip bir karantina VLAN'ına yönlendirilir.

IEEE 802.1X, NAC'nin temelini oluşturan port tabanlı bir kimlik doğrulama standardıdır. Hem kablolu (switch portları) hem de kablosuz (erişim noktaları) ağlarda erişimi kontrol etmek için kullanılır. 802.1X mimarisi üç ana bileşenden oluşur :

1. **Supplicant (İstemci)**: Ağa erişim talep eden uç nokta cihazıdır (örneğin, bir dizüstü bilgisayar veya akıllı telefon). Bu cihazda 802.1X'i destekleyen bir yazılım çalışır.
2. **Authenticator (Doğrulayıcı)**: İstemcinin ağa fiziksel olarak bağlandığı cihazdır. Kablolu ağlarda bu bir switch, kablosuz ağlarda ise bir Erişim Noktasıdır (AP). Authenticator, istemci ile kimlik doğrulama sunucusu arasında bir aracı görevi görür ve kimlik doğrulama başarılı olana kadar portu kapalı tutar.
3. **Authentication Server (Kimlik Doğrulama Sunucusu)**: İstemcinin kimlik bilgilerini doğrulayan merkezi sunucudur. Bu rolü genellikle bir **RADIUS** (Remote Authentication Dial-In User Service) sunucusu üstlenir. Sunucu, istemcinin kimlik bilgilerini (kullanıcı adı/parola, sertifika vb.) kendi veritabanı veya Active Directory gibi bir dizin hizmetiyle karşılaştırır ve Authenticator'a erişime izin verilip verilmeyeceğini bildirir.

7.2. VLAN Yönetimi, Mimarileri ve Güvenlik En İyi Pratikleri

Sanal Yerel Alan Ağları (VLAN'lar), fiziksel bir switch'i mantıksal olarak birden fazla bağımsız ağa bölme yöntemidir. Her VLAN, kendi yayın alanına (broadcast domain) sahip ayrı bir ağ gibi davranır. Bu, ağ trafiğini azaltır, performans artırır ve en önemlisi güvenliği önemli ölçüde iyileştirir. Örneğin, bir şirketteki Muhasebe, İnsan Kaynakları ve Misafir kullanıcılar için ayrı VLAN'lar oluşturularak bu departmanların trafiği birbirinden izole edilebilir.

- **VLAN'lar Arası Yönlendirme (Inter-VLAN Routing)**: Varsayılan olarak, farklı VLAN'lardaki cihazlar birbirleriyle doğrudan iletişim kuramazlar. Bu izolasyon, güvenlik için arzu edilen bir durumdur. Ancak, bazen farklı VLAN'lar arasında kontrollü iletişime izin verilmesi gerekir (örneğin, Muhasebe departmanının bir dosya sunucusuna erişmesi). Bu iletişim, OSI modelinin 3. katmanında (Ağ Katmanı) çalışan bir cihaz aracılığıyla sağlanır. Bunun için iki yaygın yöntem kullanılır:
 1. **Router-on-a-Stick**: Tek bir fiziksel router arayüzü, "alt arayüzler" (sub-interfaces) kullanılarak birden fazla VLAN için ağ geçidi görevi görür. Router, VLAN'lar arası trafiği alır, yönlendirme kararı verir ve hedef VLAN'a gönderir.
 2. **Layer 3 Switch**: Modern ağlarda daha yaygın olan bu yöntemde, yönlendirme işlevselliği doğrudan switch'in kendisine entegre edilmiştir. Bu, router-on-a-stick yöntemine göre daha hızlı ve daha verimli bir VLAN'lar arası yönlendirme sağlar.
- **Güvenlik En İyi Pratikleri**:
 - **Erişim Kontrol Listeleri (ACL'ler)**: VLAN'lar arası trafiği filtrelemek ve güvenliği sağlamak için ACL'ler kullanılır. ACL'ler, belirli IP adreslerinden, protokollerden veya portlardan gelen trafiğe izin veren veya bunları engelleyen kurallar tanımlar. Örneğin, Misafir VLAN'ından gelen tüm trafiğin kurumsal ağa erişimi bir ACL ile tamamen engellenebilir.
 - **Yönetim ve Yerel VLAN'lar**: Yönetim VLAN'ı (Management VLAN), ağ cihazlarının yönetimi için ayrılmalı ve diğer kullanıcı VLAN'larından izole edilmelidir. Varsayılan VLAN 1'in kullanılmaması ve Yerel VLAN'ın (Native VLAN) kullanılmayan bir VLAN ID'sine ayarlanması güvenlik açısından önemlidir.
 - **Kullanılmayan Portlar**: Switch'lerdeki kullanılmayan tüm portlar kapatılmalı ve belirli bir "kara delik" (black hole) VLAN'ına atanmalıdır. Bu, yetkisiz bir cihazın bu portlara takılarak ağa erişmesini engeller.

7.3. DMZ Mimarileri: Tek ve Çift Güvenlik Duvarı Tasarımları

DMZ (Demilitarized Zone - Askerden Arındırılmış Bölge), bir kurumun iç ağı (güvenilir bölge) ile internet (güvenilmeyen bölge) arasında yer alan bir tampon ağ segmentidir. Amacı, web sunucuları, e-posta sunucuları veya DNS sunucuları gibi dış dünyaya hizmet vermesi gereken sunucuları, iç ağdan izole ederek barındırmaktır. Bu sayede, DMZ'deki bir sunucu ele geçirilse bile, saldırganın doğrudan iç ağa erişmesi engellenmiş olur.

- **Tek Güvenlik Duvarı Mimarisi**: Bu tasarımda, en az üç ağ arayüzüne sahip tek bir güvenlik duvarı kullanılır: biri internete, biri iç ağa ve biri de DMZ'ye bağlanır. Güvenlik duvarı, bu üç bölge arasındaki tüm trafiği kontrol eder. Bu mimari daha basit ve daha düşük maliyetlidir, ancak



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

çok sınırlı trafiğe izin verir. Bu mimari, katmanlı bir savunma sağlar. Bir saldırgan dış güvenlik duvarını aşmış DMZ'deki bir sunucuyu ele geçirse bile, hassas verilerin bulunduğu iç ağı ulaşmak için ikinci ve daha sıkı yapılandırılmış bir güvenlik duvarını daha aşmak zorunda kalır. Bu, yanal hareket riskini önemli ölçüde azaltır ve güvenliği artırır.

Bölüm IV: Kablosuz Ağlar ve Uzak Erişim Güvenliği

Modern ağlar artık sadece fiziksel kablolarla sınırlı değildir. Kablosuz teknolojiler ve uzaktan erişim, iş dünyasına esneklik kazandırırken, aynı zamanda yeni güvenlik zorluklarını da beraberinde getirmektedir. Bu bölümde, kablosuz yerel alan ağlarının (WLAN) güvenliği ve uzaktan çalışanların kurumsal kaynaklara güvenli bir şekilde erişmesini sağlayan Sanal Özel Ağlar (VPN) teknolojileri incelenecektir.

8. Kablosuz Ağ (WLAN) Güvenliği

Kablosuz ağlar (WLAN), verileri radyo frekansları aracılığıyla ileterek cihazların fiziksel bir bağlantı olmadan ağı katılmasını sağlar. Bu yapı, doğası gereği kablolu ağlardan farklı güvenlik riskleri taşır çünkü ağ sinyalleri duvarların dışına taşabilir ve potansiyel saldırganlar tarafından dinlenebilir.

8.1. WLAN Mimarileri: WLC ve AP Yönetimi

Küçük ev veya ofis ağlarında, tek bir Erişim Noktası (Access Point - AP) genellikle yeterlidir. Ancak, kampüsler, hastaneler veya büyük şirketler gibi geniş alanlarda yüzlerce veya binlerce AP'nin yönetilmesi gerekir. Bu tür ortamlarda, her AP'yi ayrı ayrı yapılandırmak ve izlemek pratik değildir. Bu sorunu çözmek için merkezi bir yönetim mimarisi kullanılır.

- **Kablosuz LAN Denetleyicisi (WLC - Wireless LAN Controller):** WLC, bir ağdaki tüm AP'lerin merkezi olarak yönetilmesini, yapılandırılmasını ve izlenmesini sağlayan bir cihazdır. AP'ler "hafif" (lightweight) modda çalışır ve birçok kontrol ve yönetim işlevini WLC'ye devreder. WLC'nin temel işlevleri şunlardır:

- **Merkezi Yönetim:** Tüm AP'lerin yapılandırmaları (SSID'ler, güvenlik ayarları, kanallar vb.) tek bir arayüzden yapılır ve AP'lere dağıtılır.

- **AP Provizyonu ve Firmware Yönetimi:** Yeni AP'ler ağı eklendiğinde otomatik olarak yapılandırılır ve tüm AP'lerin yazılımları merkezi olarak güncellenir.

- **Güvenlik Politikalarının Uygulanması:** Kimlik doğrulama, şifreleme ve erişim kontrolü politikaları WLC üzerinden tüm kablosuz ağı uygulanır.

- **Sorunsuz Dolaşım (Seamless Roaming):** Kullanıcıların bir AP'nin kapsama alanından diğerine geçerken bağlantılarının kesilmemesini sağlar. WLC, istemci geçişlerini koordine eder.

- **Misafir Ağı Yönetimi:** Misafir kullanıcılar için ayrı, izole ve genellikle zaman veya bant genişliği sınırlı ağlar oluşturmayı kolaylaştırır.

- **CAPWAP (Control and Provisioning of Wireless Access Points) Protokolü:** AP'ler ile WLC arasındaki iletişimi sağlayan standart IETF protokolüdür. CAPWAP, iki ayrı tünel oluşturur:

- **Kontrol Tüneli (UDP Port 5246):** AP yönetimi, yapılandırma ve kontrol mesajları için kullanılır.

- **Veri Tüneli (UDP Port 5247):** İstemci verilerinin AP'den WLC'ye (veya tam tersi) tünellenmesi için kullanılır. Bu iletişim, özellikle kontrol mesajları için, **DTLS (Datagram Transport Layer Security)** kullanılarak şifrelenebilir. Bu, WLC ve AP arasındaki yönetim trafiğinin gizliliğini ve bütünlüğünü sağlar.

8.2. Kablosuz Güvenlik Standartları: WPA2 vs. WPA3

Kablosuz ağ trafiğini şifrelemek ve yetkisiz erişimi engellemek için çeşitli güvenlik protokolleri geliştirilmiştir.

- **WPA2 (Wi-Fi Protected Access 2):** Uzun yıllar boyunca kablosuz ağ güvenliğinin standardı olmuştur. Güçlü bir şifreleme algoritması olan AES-CCMP'yi kullanır. Ancak, zamanla bazı zafiyetleri ortaya çıkmıştır:

- **PSK (Pre-Shared Key) Zafiyeti:** Kişisel modda (WPA2-Personal), tüm kullanıcılar aynı parolayı (PSK) paylaşır. Bir saldırgan, bir istemci ile AP arasındaki dört yönlü el sıkışma (four-way handshake) trafiğini yakalarsa, bu trafiği kullanarak parolayı **çevrimdışı sözlük**



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

aktif bir etkileşim gerektirdiği için çevrimdışı sözlük saldırılarını imkansız hale getirir. Bu, zayıf parolalar kullanıldığında bile çok daha güçlü bir koruma sağlar.

- **Gelişmiş Açık Ağ Güvenliği:** WPA3, parola gerektirmeyen halka açık Wi-Fi ağlarında (kafeler, havaalanları vb.) bile bireysel veri şifrelemesi sağlayan "Opportunistic Wireless Encryption" (OWE) özelliğini sunar. Bu, her kullanıcı ile AP arasında benzersiz bir şifreleme anahtarı oluşturarak pasif dinlemeyi önler.

- **Daha Güçlü Şifreleme (Enterprise Modu):** WPA3-Enterprise modu, 192-bit şifreleme gücü sunarak daha yüksek güvenlik gerektiren kurumsal ortamlar için daha sağlam bir seçenek sunar.

WPA3'e geçiş, hem AP'lerin hem de istemci cihazların bu standardı desteklemesini gerektirir. Birçok modern cihaz, geriye dönük uyumluluk için hem WPA2 hem de WPA3'ü destekleyen bir "geçiş modu" (transition mode) sunmaktadır.

9. Sanal Özel Ağlar (VPN)

Sanal Özel Ağ (VPN), kullanıcıların veya kurumsal ağların, internet gibi halka açık ve güvenilmeyen bir ağ üzerinden sanki özel bir ağa doğrudan bağlıymış gibi güvenli bir şekilde iletişim kurmasını sağlayan bir teknolojidir. VPN, verileri şifreleyerek ve bir "tünel" içinden geçirerek gizlilik ve bütünlük sağlar.

9.1. VPN Mimarileri: Site-to-Site ve Uzaktan Erişim (Remote Access)

VPN'ler, kullanım senaryolarına göre iki ana mimaride uygulanır:

- **Siteden Siteye VPN (Site-to-Site VPN):** Bu mimari, coğrafi olarak farklı konumlarda bulunan iki veya daha fazla kurumsal ağı (örneğin, bir şirketin merkez ofisi ile şube ofisleri) internet üzerinden güvenli bir şekilde birbirine bağlamak için kullanılır. "Router-to-Router VPN" olarak da bilinir. Bu modelde, her bir lokasyondaki ağ geçidi cihazları (güvenlik duvarı veya router) arasında kalıcı bir VPN tüneli kurulur. O lokasyondaki kullanıcıların cihazlarına herhangi bir istemci yazılımı yüklemesi gerekmez; tüm trafik ağ geçidi üzerinden otomatik olarak tünellenir. Bu, şube ofislerindeki kullanıcıların merkez ofisteki sunuculara ve kaynaklara sorunsuz bir şekilde erişmesini sağlar.
- **Uzaktan Erişim VPN (Remote Access VPN):** Bu mimari, bireysel kullanıcıların (örneğin, evden çalışanlar, seyahat eden satış temsilcileri) kurumsal ağa güvenli bir şekilde bağlanmasını sağlamak için tasarlanmıştır. Kullanıcının dizüstü bilgisayar, tablet veya akıllı telefon gibi cihazına bir **VPN istemci yazılımı** yüklenmesi gerekir. Kullanıcı bu yazılımı çalıştırıp kimlik bilgilerini girdiğinde, cihazı ile kurumsal ağdaki VPN sunucusu arasında geçici ve güvenli bir tünel oluşturulur. Bu, kullanıcının sanki ofisteymiş gibi şirket içi kaynaklara erişmesine olanak tanır.

9.2. VPN Protokolleri: IPsec ve SSL/TLS Karşılaştırması

VPN tünellerinin güvenliğini sağlamak için çeşitli protokoller kullanılır. En yaygın olan iki protokol ailesi IPsec ve SSL/TLS'dir. Bu iki protokol, farklı OSI katmanlarında çalışır ve farklı güvenlik yaklaşımları sunar.

- **IPsec (Internet Protocol Security):** OSI modelinin 3. katmanında (Ağ Katmanı) çalışan bir protokol takımıdır. Bu katmanda çalıştığı için, üzerindeki uygulama veya protokolden bağımsız olarak **tüm IP trafiğini** şifreleyebilir. Bu, kullanıcılara tam ağ erişimi sağlar ve genellikle Site-to-Site VPN'ler için tercih edilen standarttır.

- **Ana Bileşenleri:**

- **AH (Authentication Header):** Veri bütünlüğü ve kimlik doğrulama sağlar, ancak şifreleme yapmaz.

- **ESP (Encapsulating Security Payload):** Şifreleme, veri bütünlüğü ve kimlik doğrulama sağlar. Genellikle tek başına kullanılır.

- **Çalışma Modları:**

- **Transport Mode:** Sadece IP paketinin veri yükünü (payload) şifreler, orijinal IP başlığına dokunmaz. Genellikle uçtan uca iletişimde kullanılır.

- **Tunnel Mode:** Tüm orijinal IP paketini (başlık ve yük dahil) şifreler ve yeni bir IP başlığı ekler. Bu, ağ geçitleri arasında (Site-to-Site VPN) trafiği tünellemek için kullanılır.

- **İlgili IETF RFC'leri:** IPsec'in temelini oluşturan standartlar arasında RFC 4301-4309 serisi bulunur.

- **SSL/TLS VPN:** Bu VPN türü, web tarayıcılarının güvenli web siteleriyle (HTTPS) iletişim kurmak için kullandığı Güvenli Yuva Katmanı (SSL) ve onun halefi olan Taşıma Katmanı Güvenliği (TLS) protokollerini kullanır. OSI modelinin 7. katmanında (Uygulama Katmanı) çalışır.



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

Özellik	IPsec VPN	SSL/TLS VPN
OSI Katmanı	Katman 3 (Ağ)	Katman 7 (Uygulama)
Güvenlik Kapsamı	Tüm IP trafiğini korur	Genellikle belirli uygulamaları veya web trafiğini korur
İstemci Yazılımı	Genellikle gereklidir	Genellikle standart web tarayıcısı yeterlidir
Erişim Kontrolü	Geniş ağ erişimi	Granüler, uygulama bazlı erişim
Kurulum ve Yönetim	Daha karmaşık	Daha basit ve esnek
Tipik Kullanım	Site-to-Site VPN	Remote Access VPN

Bölüm V: Modern Ağ Mimarileri ve Paradigma Değişimleri

Geleneksel ağ mimarileri, statik yapıları ve donanım bağımlılıkları nedeniyle bulut bilişim, mobilite ve Nesnelerin İnterneti (IoT) gibi modern BT trendlerinin getirdiği dinamik talepleri karşılamakta zorlanmaktadır. Bu bölümde, ağ yönetimini ve güvenliğini kökten değiştiren yazılım tabanlı yaklaşımlar, "asla güvenme, her zaman doğrula" felsefesini benimseyen Sıfır Güven mimarisi ve web performansını optimize eden modern dağıtım teknolojileri incelenecektir.

10. Yazılım Tanımlı Ağlar (SDN & SD-WAN)

Yazılım tanımlı ağlar, ağ kontrolünü ve yönetimini donanımdan soyutlayarak merkezi ve programlanabilir bir yapıya kavuşturan devrimci bir yaklaşımdır.

10.1. SDN Mimarisi ve Güvenlik Avantajları

Yazılım Tanımlı Ağ (SDN), geleneksel ağ cihazlarının (router, switch) iki temel işlevini birbirinden ayırma prensibine dayanır: **kontrol düzlemi (control plane)** ve **veri düzlemi (data plane)**. Kontrol düzlemi, trafiğin nereye gideceğine dair kararları verirken (yönlendirme tablolarını oluşturur), veri düzlemi bu kararlara uyarak paketleri fiziksel olarak iletir. Geleneksel ağlarda bu iki düzlem her cihazın kendi içinde birleşiktir. SDN ise kontrol düzlemini tüm cihazlardan alıp, **merkezi bir SDN denetleyicisi (controller)** üzerinde birleştirir. Veri düzlemi ise basit iletme görevini yerine getiren donanımlarda kalır.

• Güvenlik Avantajları:

- **Merkezi Görünürlük ve Kontrol:** Tüm ağın kontrol mantığı tek bir merkezde toplandığı için, ağ genelinde tutarlı ve dinamik güvenlik politikaları uygulamak çok daha kolay hale gelir. Bir tehdit tespit edildiğinde, denetleyici tüm ağı kapsayan bir engelleme kuralını anında dağıtabilir.
- **Dinamik Tehdit Müdahalesi:** SDN, şüpheli trafik akışlarını analiz için bir "bal küpü"ne (honeypot) yönlendirebilir veya enfekte olmuş bir cihazı anında ağdan izole edebilir.

• Güvenlik Dezavantajları ve Önlemler:

- **Merkezi Saldırı Yüzeyi:** SDN'in en büyük gücü olan merkezi denetleyici, aynı zamanda en büyük zayıflığıdır. Denetleyici, ağın "beyni" olduğu için saldırganlar için çok değerli bir hedef haline gelir. Denetleyicinin ele geçirilmesi, tüm ağın kontrolünün kaybedilmesi anlamına gelebilir.
- **Alınacak Önlemler:** Bu riski azaltmak için denetleyicinin kendisinin çok katmanlı güvenlik önlemleriyle (hardening) korunması, denetleyiciler arasında yedeklilik sağlanması ve denetleyici ile ağ cihazları arasındaki iletişimin (örneğin, OpenFlow protokolü) şifrelenmesi ve güvenli hale getirilmesi kritik öneme sahiptir.

10.2. SD-WAN vs. MPLS: Güvenlik ve Uygulama Farkındalığı

Geniş Alan Ağı (WAN), bir şirketin coğrafi olarak dağılmış şubelerini ve veri merkezlerini birbirine bağlayan ağıdır.

- **MPLS (Multi-Protocol Label Switching):** Yıllardır kurumsal WAN bağlantıları için altın standart olmuştur. Servis sağlayıcılar tarafından sunulan özel, güvenilir ve öngörülebilir performansa sahip bir bağlantı türüdür. Ancak, MPLS hatları oldukça **pahalıdır**, kurulumu uzun sürer ve **esnek değildir**. Ayrıca, bulut tabanlı uygulamalara (SaaS) yönelik artan trafiği verimli bir şekilde



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

düşük gecikmeye sahip yolu (örneğin MPLS) seçerken, daha az kritik trafik için internet bağlantısını kullanabilir.

• **Entegre Güvenlik:** Birçok SD-WAN çözümü, NGFW, IPSec VPN tünelleme ve ağ segmentasyonu gibi yerleşik güvenlik özellikleri sunar.

• **SASE (Secure Access Service Edge) ile Entegrasyon:** SD-WAN, modern güvenlik mimarisi olan SASE'nin temel bir bileşenidir. SASE, ağ (SD-WAN) ve güvenlik işlevlerini bulut tabanlı tek bir hizmette birleştirir. Bu entegrasyon sayesinde, şubeler ve uzaktan çalışanlar için **Sıfır Güven Ağ Erişimi (ZTNA)**, **Hizmet Olarak Güvenlik Duvarı (FWaaS)** ve **Güvenli Web Ağ Geçidi (SWG)** gibi gelişmiş güvenlik hizmetleri, kullanıcının veya cihazın konumundan bağımsız olarak tutarlı bir şekilde uygulanabilir.

11. Sıfır Güven (Zero Trust) Mimarisi

Sıfır Güven (Zero Trust), geleneksel "güven ama doğrula" (trust but verify) modelini tamamen reddeden ve "asla güvenme, her zaman doğrula" (never trust, always verify) felsefesini benimseyen bir siber güvenlik stratejisidir. Bu modelde, ağın içinde veya dışında olmasından bağımsız olarak hiçbir kullanıcıya, cihaza veya uygulamaya varsayılan olarak güvenilmez.

11.1. NIST SP 800-207 İlkeleri ve Uygulamaları

ABD Ulusal Standartlar ve Teknoloji Enstitüsü (NIST), SP 800-207 belgesinde Sıfır Güven Mimarisi (ZTA) için bir çerçeve ve temel ilkeler tanımlamıştır. Bu ilkeler, geleneksel çevre tabanlı güvenlik modelinden köklü bir kopuşu temsil eder. Çevre tabanlı model, bir "kale ve hendek" gibi, dışarıyı güvensiz, içeriye ise güvenli kabul eder. Sıfır Güven ise bir ihlalin zaten gerçekleştiğini varsayar ve her erişim talebini, kaynağı ne olursa olsun, şüpheyile yaklaşıp doğrulamaya tabi tutar.

• NIST Sıfır Güven İlkeleri (Tenets):

1. **Tüm Veri Kaynakları ve Bilişim Hizmetleri Kaynak Olarak Kabul Edilir:** Cihazlar, uygulamalar, SaaS hizmetleri dahil her şey bir kaynaktır ve korunmalıdır.
2. **Tüm İletişim, Ağ Konumundan Bağımsız Olarak Güvenli Hale Getirilir:** İç ağda (LAN) olmak, bir cihaza veya kullanıcıya ek bir güven kredisi sağlamaz.
3. **Bireysel Kurumsal Kaynaklara Erişim, Oturum Bazında Verilir:** Bir kaynağa erişim izni, başka bir kaynağa erişim izni anlamına gelmez. Her istek ayrı ayrı değerlendirilir.
4. **Kaynaklara Erişim, Dinamik Politikalarla Belirlenir:** Erişim kararları, sadece kullanıcı kimliğine değil, aynı zamanda cihazın sağlık durumu, coğrafi konum, zaman ve diğer davranışsal ve çevresel özniteliklere dayalı olarak anlık verilir.
5. **Kurum, Sahip Olduğu ve İlişkili Tüm Varlıkların Bütünlüğünü ve Güvenlik Duruşunu İzler ve Ölçer:** Hiçbir cihaza körü körüne güvenilmez; güvenlik durumu sürekli olarak izlenir ve zafiyetler giderilir.
6. **Tüm Kaynak Kimlik Doğrulaması ve Yetkilendirmesi Dinamiktir ve Erişim İzin Verilmeden Önce Sıkı Bir Şekilde Uygulanır:** Bu, sürekli bir kimlik doğrulama, yetkilendirme, tarama ve değerlendirme döngüsüdür.

11.2. Mikro-Segmentasyon ile Yanal Hareketin Önlenmesi

Mikro-segmentasyon, Sıfır Güven mimarisinin pratikte uygulanmasındaki en önemli tekniklerden biridir. Ağın, her biri kendi güvenlik politikalarına sahip çok küçük ve granüler güvenlik bölgelerine ayrılmasıdır. Geleneksel ağ segmentasyonu (VLAN'lar gibi) genellikle büyük ağ segmentleri oluştururken, mikro-segmentasyon iş yükü veya uygulama düzeyinde izolasyon sağlar.

- **Yanal Hareketin (Lateral Movement) Engellenmesi:** Bir saldırgan, geleneksel bir ağda bir uç noktayı (örneğin, bir çalışanın dizüstü bilgisayarını) ele geçirdiğinde, genellikle ağ içinde serbestçe hareket ederek (yanal hareket) daha değerli hedeflere (sunucular, veritabanları) ulaşmaya çalışır. Mikro-segmentasyon, bu yanal hareketi engeller. Ele geçirilen bir iş yükü, yalnızca işlevini yerine getirmek için kesinlikle iletişim kurması gereken diğer iş yükleriyle konuşabildiği için, saldırganın hareket alanı büyük ölçüde kısıtlanır. Bu, bir ihlalin "patlama yarıçapını" (blast radius) önemli ölçüde azaltır.
- **Uygulama Yaklaşımları:**
 - **Ağ Tabanlı Mikro-segmentasyon:** Güvenlik duvarları, switch'ler veya SDN gibi ağ altyapısı bileşenlerini kullanarak segmentler arasında trafik akışını kontrol eder.
 - **Ajan Tabanlı (Agent-based) Mikro-segmentasyon:** Her bir sunucuya veya iş yüküne kurulan bir yazılım ajanı aracılığıyla, ana bilgisayarın kendi güvenlik duvarı (host-based



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

12.1. Yük Dengeleyiciler (Load Balancers): Algoritmalar ve Yüksek Erişilebilirlik

Yük dengeleyici, gelen ağ trafiğini veya uygulama isteklerini, aynı hizmeti sunan birden fazla sunucudan oluşan bir sunucu havuzuna (server farm) akıllıca dağıtan bir cihaz veya yazılımdır. Temel amacı, tek bir sunucunun aşırı yüklenmesini önlemek, kaynak kullanımını optimize etmek, yanıt sürelerini iyileştirmek ve yüksek erişilebilirlik (high availability) sağlamaktır.

• Temel İşlevler:

- **Yüksek Erişilebilirlik ve Yük Devretme (Failover):** Yük dengeleyiciler, sunucuların sağlık durumunu düzenli olarak **sağlık kontrolleri (health checks)** ile (örneğin, belirli bir porta TCP bağlantısı kurarak veya bir HTTP yanıtı bekleyerek) izler. Bir sunucu yanıt vermezse, onu otomatik olarak havuzdan çıkarır ve trafiği sağlıklı sunuculara yönlendirir. Bu, bir sunucu arızası durumunda bile hizmetin kesintisiz devam etmesini sağlar.
- **Ölçeklenebilirlik (Scalability):** Trafik arttığında, sunucu havuzuna kolayca yeni sunucular eklenebilir ve yük dengeleyici bu yeni sunuculara da trafik yönlendirmeye başlar.
- **SSL Sonlandırma (SSL Termination):** Gelen HTTPS trafiğinin şifresini çözme işlemini kendi üzerinde yaparak, bu işlemci yoğun görevi arka plandaki web sunucularından alır ve performanslarını artırır.
- **Oturum Sürekliliği (Session Persistence / Sticky Sessions):** Bazı uygulamalar (örneğin, e-ticaret sitelerindeki alışveriş sepetleri), bir kullanıcının tüm oturumu boyunca aynı sunucuya bağlı kalmasını gerektirir. Yük dengeleyiciler, kullanıcının IP adresine veya bir çerez (cookie) bakarak bu sürekliliği sağlayabilir.

• Yük Dengeleme Algoritmaları:

- **Round Robin:** Gelen istekleri sırayla sunuculara dağıtır. En basit algoritmadır ve tüm sunucuların eşit kapasitede olduğu varsayımına dayanır.
- **Weighted Round Robin:** Her sunucuya kapasitesine göre bir ağırlık atanır. Daha güçlü sunucular daha fazla istek alır.
- **Least Connection:** Yeni bir isteği, o an en az aktif bağlantıya sahip olan sunucuya yönlendirir. Bu, yükün daha dengeli dağılmasını sağlar.
- **IP Hash:** İsteği yapan istemcinin IP adresinden bir hash oluşturur ve bu hash değerine göre isteği belirli bir sunucuya yönlendirir. Bu, aynı istemciden gelen tüm isteklerin aynı sunucuya gitmesini sağlayarak oturum sürekliliğini garanti eder.

12.2. İçerik Dağıtım Ağları (CDN) ve DDoS Koruması

İçerik Dağıtım Ağı (CDN), bir web sitesinin statik içeriklerini (resimler, videolar, CSS, JavaScript dosyaları vb.) coğrafi olarak dünyanın dört bir yanına dağıtılmış **uç sunucularda (edge servers)** ön belleğe alan (caching) bir hizmettir. Bir kullanıcı web sitesine erişmek istediğinde, içerik orijinal sunucudan (origin server) değil, kullanıcıya coğrafi olarak en yakın olan uç sunucudan teslim edilir.

• Performans Artışı:

- **Azaltılmış Gecikme (Latency):** Verinin kat etmesi gereken fiziksel mesafeyi kısaltarak web sayfalarının yüklenme süresini önemli ölçüde azaltır. Bu, özellikle küresel bir kitleye hizmet veren web siteleri için kritik öneme sahiptir.
- **Yük Dengeleme:** CDN'ler, gelen trafiği küresel olarak dağıtılmış sunucu ağına yayarak orijinal sunucu üzerindeki yükü azaltır. Bu, trafik ani bir şekilde arttığında bile sitenin erişilebilir kalmasını sağlar.

- **DDoS Koruması:** CDN'lerin devasa ve dağıtılmış altyapısı, onları Dağıtılmış Hizmet Reddi (DDoS) saldırılarına karşı doğal bir savunma mekanizması haline getirir. Bir DDoS saldırısı başladığında, saldırı trafiği tek bir hedefe (orijinal sunucu) odaklanmak yerine, CDN'nin dünya geneline yayılmış yüzlerce veya binlerce sunucusu tarafından **absorbe edilir ve dağıtılır**. Bu, saldırının etkisini büyük ölçüde seyletir ve orijinal sunucunun ayakta kalarak meşru kullanıcılara hizmet vermeye devam etmesini sağlar.

Bölüm VI: Kimlik ve Erişim Yönetimi (IAM)

Kimlik ve Erişim Yönetimi (IAM), bir organizasyonun dijital kaynaklarına doğru kişilerin, doğru koşullar altında ve doğru nedenlerle erişmesini sağlayan politika ve teknolojiler bütünüdür. Modern ağ güvenliğinin temel direklerinden biridir ve "kimin neye erişebileceğini" yönetir. Bu bölüm, IAM'in temel çerçevesi olan AAA'dan başlayarak, günümüzün karmaşık kimlik doğrulama ve yetkilendirme zorluklarına çözüm sunan modern teknolojilere kadar uzanacaktır.



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

veri veya güvenlik anahtarı gibi bir kimlik bilgisi sunulur yapıılır.

• **Authorization (Yetkilendirme):** "Ne yapmana izin var?" sorusuna yanıt verir. Kimliği doğrulanmış bir kullanıcının hangi kaynaklara (dosyalar, uygulamalar, ağ segmentleri vb.) erişebileceğini ve bu kaynaklar üzerinde hangi işlemleri (okuma, yazma, silme vb.) yapabileceğini belirleme sürecidir. Bu, genellikle en az ayrıcalık ilkesine (principle of least privilege) göre yapılır.

• **Accounting (Hesap Verebilirlik / İzleme):** "Ne yaptın?" sorusuna yanıt verir. Kullanıcının ağ kaynaklarını nasıl kullandığını izleme ve kaydetme sürecidir. Bu, oturum açma zamanları, erişilen kaynaklar, gerçekleştirilen komutlar ve aktarılan veri miktarı gibi bilgileri içerir. Bu kayıtlar, güvenlik denetimleri, sorun giderme ve faturalandırma için kullanılır.

Bu üç prensip, özellikle Sıfır Güven (Zero Trust) mimarisiyle yakından ilişkilidir. Sıfır Güven, her erişim talebi için sıkı kimlik doğrulama (Authentication) ve dinamik, granüler yetkilendirme (Authorization) gerektirir. Aynı zamanda, tüm aktivitelerin sürekli olarak izlenmesi ve denetlenmesi (Accounting) ilkesini benimser.

13.2. RADIUS ve TACACS+ Karşılaştırması

RADIUS ve TACACS+, AAA çerçevesini uygulamak için kullanılan iki yaygın ağ protokolüdür. Özellikle ağ cihazlarına (router, switch, VPN sunucusu vb.) erişimi merkezi olarak yönetmek için kullanılırlar. Aralarında önemli teknik farklar bulunmaktadır.

• RADIUS (Remote Authentication Dial-In User Service):

- **Taşıma Protokolü:** Güvenilmez bir taşıma protokolü olan **UDP**'yi kullanır (port 1812/1813).
- **Şifreleme:** Yalnızca kullanıcı **parolasını** şifreler. Kullanıcı adı, yetkilendirme bilgileri ve diğer öznitelikler düz metin olarak gönderilir, bu da onu daha az güvenli kılar.
- **AAA Süreçleri:** Kimlik doğrulama ve yetkilendirme süreçlerini **birleştirir**. Bir kullanıcı kimliğini doğruladığında, yetkileri de aynı paket içinde gönderilir. Bu, daha az esneklik anlamına gelir.
- **Yetkilendirme:** Komut bazında ayrıntılı yetkilendirme yeteneği yoktur. Genellikle kullanıcıya tam erişim verir veya erişimi tamamen reddeder.
- **Standart:** Açık bir IETF standardıdır ve çok çeşitli satıcıların ürünleri tarafından desteklenir.

• TACACS+ (Terminal Access Controller Access-Control System Plus):

- **Taşıma Protokolü:** Güvenilir bir taşıma protokolü olan **TCP**'yi kullanır (port 49).
- **Şifreleme:** İstemci ve sunucu arasındaki **tüm paketi** şifreler, bu da onu çok daha güvenli hale getirir.
- **AAA Süreçleri:** Kimlik doğrulama, yetkilendirme ve hesap verebilirlik süreçlerini birbirinden **ayırır**. Bu, farklı kimlik doğrulama ve yetkilendirme yöntemlerinin bir arada kullanılmasına olanak tanıyarak büyük bir esneklik sağlar.
- **Yetkilendirme:** En büyük avantajlarından biri, **komut bazında yetkilendirme** yapabilmesidir. Bir yöneticinin hangi komutları çalıştırıp çalıştıramayacağını ayrıntılı olarak belirlemeye olanak tanır.
- **Standart:** Cisco tarafından geliştirilmiştir ve genellikle Cisco'ya özgü olarak kabul edilir, ancak birçok başka satıcı tarafından da desteklenmektedir.

Aşağıdaki tablo, iki protokol arasındaki temel farkları özetlemektedir:

Özellik	RADIUS	TACACS+
Taşıma Protokolü	UDP (1812, 1813)	TCP (49)
Şifreleme	Sadece Parola	Tüm Paket
AAA Süreçleri	Kimlik Doğrulama ve Yetkilendirme Birleşik	Ayrı Süreçler
Yetkilendirme	Hepsi ya da hiçbiri	Komut Bazında Granüler
Standart	Açık (IETF)	Cisco Tarafından Geliştirilmiş

Genel olarak, ağ cihazı yönetimi ve granüler kontrol gerektiren ortamlar için TACACS+ daha üstün bir seçenekken, kullanıcı erişim kontrolü (örneğin, 802.1X veya VPN) için RADIUS'un geniş satıcı desteği onu popüler kılmaktadır.

14. Modern Kimlik Doğrulama Yöntemleri

Parolalar, uzun süredir kimlik doğrulamanın temel taşı olmasına rağmen, zayıf, yeniden kullanılan veya çalınan parolalar en yaygın siber güvenlik zafiyetlerinden birini oluşturmaktadır. Bu riski azaltmak için daha güçlü ve kullanıcı dostu modern kimlik doğrulama yöntemleri geliştirilmiştir.



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

Authenticator gibi uygulamalar veya anlık onay bildirimleri (push notifications).

- **Donanım Anahtarı (Hardware Token):** FIDO2 standartlarını destekleyen YubiKey gibi USB veya NFC tabanlı fiziksel güvenlik anahtarları.

3. **Olduğunuz Bir Şey (Inherence Factor):** Kullanıcının benzersiz biyolojik özellikleridir. Örnekler arasında **parmak izi taraması, yüz tanıma** veya retina taraması yer alır.

Etkili bir MFA uygulaması, bu üç kategoriden en az ikisini birleştirmelidir. Örneğin, parola (bildiğiniz) ile telefonunuza gelen bir kod (sahip olduğunuz) iki faktörlü kimlik doğrulama (2FA) olarak kabul edilir.

14.2. Parolasız Kimlik Doğrulama (Passwordless) ve FIDO2/WebAuthn

Parolasız kimlik doğrulama, parolaların doğasında var olan riskleri (kimlik avı, yeniden kullanım, zayıflık) tamamen ortadan kaldırmayı hedefler. Bu alandaki en önemli gelişme, FIDO (Fast Identity Online) Alliance tarafından geliştirilen **FIDO2** standardıdır. FIDO2, iki ana bileşenden oluşur :

- **WebAuthn (Web Authentication):** Tarayıcıların ve web uygulamalarının FIDO kimlik doğrulayıcılarıyla iletişim kurmasını sağlayan bir W3C web standardı API'sidir.

- **CTAP (Client to Authenticator Protocol):** Bir bilgisayarın, YubiKey gibi harici bir güvenlik anahtarıyla veya bir akıllı telefonla iletişim kurmasını sağlayan protokoldür.

Çalışma Prensipleri: FIDO2, parola yerine **açık anahtar kriptografisine** dayanır. Süreç şu şekilde işler :

1. **Kayıt (Registration):** Bir kullanıcı bir hizmete ilk kez kaydolduğunda, kullanıcının cihazı (veya güvenlik anahtarı) bir **özel anahtar** ve bir **açık anahtar** çifti oluşturur. Özel anahtar, cihazın güvenli donanımında (örneğin, bir TPM çipi) saklanır ve cihazdan asla ayrılmaz. Açık anahtar ise kullanıcının kimliğiyle ilişkilendirilerek hizmetin sunucusuna gönderilir. Bu aşamada sunucuda hiçbir parola veya paylaşılan sır saklanmaz.

2. **Kimlik Doğrulama (Authentication):** Kullanıcı daha sonra hizmete giriş yapmak istediğinde, hizmet sunucusu kullanıcıya bir "meydan okuma" (challenge) gönderir. Kullanıcının cihazı, bu meydan okumayı cihazda saklanan **özel anahtar** ile imzalar. Bu imzalama işlemi, kullanıcının kendisini cihaz üzerinde doğrulamasıyla (örneğin, parmak izini okutarak veya PIN girerek) tetiklenir. İmzalanan yanıt sunucuya geri gönderilir. Sunucu, daha önce sakladığı açık anahtarı kullanarak imzayı doğrular. İmza geçerliyse, kullanıcıya erişim izni verilir.

Bu yöntem, parola olmadığı için kimlik avı saldırılarına karşı son derece dirençlidir ve sunucu tarafında bir veri sızıntısı olsa bile saldırganların ele geçirebileceği bir parola karması bulunmaz.

14.3. Tek Oturum Açma (SSO): SAML ve OpenID Connect (OIDC) Akışları

Tek Oturum Açma (SSO), kullanıcıların tek bir kimlik bilgisi seti ile birden fazla farklı, bağımsız uygulamaya ve hizmete erişmesine olanak tanıyan bir kimlik doğrulama yöntemidir. Bu, hem kullanıcı deneyimini iyileştirir hem de parola yönetimini merkezileştirerek güvenliği artırır. SSO'yu uygulamak için iki yaygın federasyon protokolu kullanılır:

- **SAML (Security Assertion Markup Language):** XML tabanlı, olgun ve genellikle kurumsal (enterprise) uygulamalar arasında SSO sağlamak için kullanılan bir standarttır. SAML akışında üç ana taraf bulunur: kullanıcı (tarayıcısı aracılığıyla), **Hizmet Sağlayıcı (SP - Service Provider)** (kullanıcının erişmek istediği uygulama) ve **Kimlik Sağlayıcı (IdP - Identity Provider)** (kullanıcının kimliğini doğrulayan ve yöneten merkezi otorite, örneğin Microsoft Entra ID veya Okta).

- **SP Tarafından Başlatılan Akış (SP-Initiated Flow):**

1. Kullanıcı, SP'nin web sitesine erişmeye çalışır.

2. SP, kullanıcının kimliğinin doğrulanmadığını görür ve bir **SAML İsteği**

- (**SAMLRequest**) oluşturur. Bu isteği kullanıcının tarayıcısına bir HTTP yönlendirmesi (Redirect) veya POST isteği ile göndererek kullanıcıyı IdP'ye yönlendirir.

3. Kullanıcı, IdP'nin oturum açma sayfasında kimliğini doğrular.

4. IdP, kullanıcının kimliğini, özniteliklerini ve yetkilerini içeren bir **SAML Onayı (SAML Assertion)** oluşturur. Bu onayı dijital olarak imzalar.

5. IdP, bu onayı içeren bir **SAML Yanıtını (SAMLResponse)** kullanıcının tarayıcısına bir HTTP POST isteği ile gönderir ve tarayıcıyı tekrar SP'ye yönlendirir.

6. SP, SAML Yanıtını alır, IdP'nin dijital imzasını doğrular, onayı işler ve kullanıcı için bir oturum oluşturur.

- **OpenID Connect (OIDC):** OAuth 2.0 yetkilendirme çerçevesi üzerine inşa edilmiş, JSON ve REST tabanlı modern bir kimlik doğrulama katmanıdır. Özellikle mobil ve modern web uygulamaları için tasarlanmıştır. OIDC'de SAML'deki SP'ye **Bağlı Taraf (RP - Relying Party)**, IdP'ye ise **OpenID Sağlayıcısı (OP - OpenID Provider)** denir.



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

6. RP, arka kanalda (kullanıcının tarayıcısı olmadan) OP'nin **token endpoint'ine (token endpoint)** bir istek gönderir. Bu istek, aldığı yetkilendirme kodunu ve kendi kimlik bilgilerini (client_id ve client_secret) içerir.

7. OP, yetkilendirme kodunu ve istemci kimlik bilgilerini doğrular ve RP'ye iki önemli belirteç (token) döndürür:

■ **ID Token:** Kullanıcının kimlik doğrulama bilgilerini (kullanıcı kimliği, veren, son kullanma tarihi vb.) içeren bir JWT'dir. RP tarafından okunmak ve doğrulanmak içindir.

■ **Access Token:** RP'nin, kullanıcı adına korumalı kaynaklara (örneğin bir API'ye) erişmek için kullanacağı bir belirteçtir. İçeriği RP için opak olabilir.

Bölüm VII: Kritik Altyapı ve Protokol Güvenliği

Modern ağlar, sadece uç noktalardan ve sunuculardan ibaret değildir. Arka planda, tüm dijital iletişimin ve kurumsal yönetimin bel kemiğini oluşturan kritik altyapı hizmetleri ve protokoller çalışır. Bu bölümde, kurumsal ağların merkezinde yer alan Active Directory'nin güvenliği, internetin temelini oluşturan SMTP, HTTP ve DNS gibi protokollerin nasıl güvence altına alındığı ve küresel internet yönlendirmesini yöneten BGP'nin zafiyetleri ve korunma yöntemleri incelenecektir.

15. Active Directory Ağı Güvenliği

Microsoft Active Directory (AD), günümüzdeki kurumsal ağların %95'inde kullanılan, kullanıcı kimliklerini, bilgisayarları, politikaları ve kaynakları merkezi olarak yöneten bir izin hizmetidir. Bu merkezi rolü, onu saldırganlar için birincil hedef haline getirmektedir.

15.1. AD Mimarisi: Forest, Domain, DC ve OU Yapıları

Active Directory, nesneleri hiyerarşik bir yapıda organize eder. Bu yapının anlaşılması, güvenlik sınırlarını ve potansiyel saldırı yüzeylerini kavramak için esastır.

- **Forest (Orman):** AD yapısındaki en üst düzey mantıksal konteynerdir. Bir veya daha fazla domain tree'den oluşur ve bir organizasyonun tüm AD nesnelerini kapsar. Bir forest içindeki tüm domain'ler ortak bir şema ve global katalog paylaşır ve aralarında varsayılan olarak iki yönlü güven ilişkisi bulunur. Forest, AD'nin güvenlik sınırını tanımlar; bir forest'taki yöneticilerin diğer forest'lar üzerinde varsayılan olarak yetkisi yoktur.
- **Domain (Etki Alanı):** Bir yönetim sınırıdır ve kullanıcı hesapları, bilgisayarlar ve grup politikaları gibi nesneleri içerir. Bir forest içindeki domain'ler, contoso.com gibi ortak bir ad alanını paylaşan bir hiyerarşi (domain tree) oluşturabilir.
- **Domain Controller (DC - Etki Alanı Denetleyicisi):** Bir domain'in veritabanının (NTDS.dit dosyası) bir kopyasını barındıran ve o domain için kimlik doğrulama (örneğin, kullanıcı oturum açma) ve yetkilendirme isteklerini işleyen bir sunucudur.
- **Organizational Unit (OU - Organizasyonel Birim):** Bir domain içindeki kullanıcıları, grupları ve bilgisayarları mantıksal olarak gruplamak için kullanılan bir konteynerdir. OU'lar, yönetimsel görevleri delege etmek ve Grup Politikaları (GPO) uygulamak için kullanılır.

15.2. AD ve DNS Entegrasyonu: SRV Kayıtları ve Güvenli DDNS

Active Directory, işlevselliği için DNS'e (Domain Name System) kritik derecede bağımlıdır. Bir istemci veya sunucu, kimlik doğrulaması yapmak, bir kaynağı bulmak veya replikasyon yapmak için bir Domain Controller'ı bulmak zorundadır ve bu bulma işlemi tamamen DNS üzerinden gerçekleşir.

- **SRV (Service Locator) Kayıtlarının Rolü:** DC'ler, sundukları hizmetleri (LDAP, Kerberos, Global Catalog vb.) ağdaki diğer bilgisayarlara tanıtmak için DNS'e otomatik olarak özel **SRV kayıtları** kaydederler. Bu kayıtlar, bir hizmetin hangi sunucuda ve hangi portta çalıştığını belirtir.
- **DC Bulma Süreci:** Bir istemci, bir DC ile iletişim kurması gerektiğinde, aşağıdaki adımları izler:
 1. İstemci, kendi yerel DNS sunucusuna, belirli bir hizmet için bir SRV kaydı sorgusu gönderir. Örneğin, contoso.com domain'i için bir LDAP sunucusu (yani bir DC) bulmak amacıyla _ldap._tcp.dc._msdcs.contoso.com şeklinde bir sorgu yapar.
 2. DNS sunucusu, bu sorguya yanıt olarak, bu hizmeti sunan tüm DC'lerin bir listesini (sunucu adları, port numaraları, öncelik ve ağırlık bilgileriyle birlikte) döndürür.
 3. İstemci, bu listeden bir DC seçer ve onunla iletişim kurar.



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

aynı dokümanın yukarıdakiyle ve aşağıdakiyle sağlanmaya çalışılır.

- **Kerberoasting:** Bu, bir saldırganın, Active Directory'deki **servis hesaplarının** (Service Principal Name - SPN'e sahip hesaplar) parola hash'lerini ele geçirmeyi amaçlayan bir post-exploitation tekniğidir.
 - **Saldırı Adımları:**
 1. Saldırgan, ağda düşük yetkili, geçerli bir kullanıcı hesabı elde eder.
 2. Bu hesapla, ağdaki SPN'e sahip tüm servis hesaplarını (örneğin, SQL Server veya web sunucusu servisleri) sorgular.
 3. Saldırgan, hedef servis hesabı için bir Kerberos Bilet Verme Hizmeti (TGS) bileti talep eder. Kerberos protokolü gereği, DC bu bileti, isteyen kullanıcının yetkisi olup olmadığını kontrol etmeden, hedef servis hesabının parolasıyla şifrelenmiş olarak verir.
 4. Saldırgan, bu şifrelenmiş bileti alır ve **çevrimdışı (offline)** olarak kaba kuvvet (brute-force) veya sözlük saldırılarıyla kırmaya çalışır. Servis hesabının parolası zayıfsa, saldırgan parolayı kısa sürede ele geçirebilir

Works cited

1. What's The CIA Triad? Confidentiality, Integrity, & Availability ..., https://www.splunk.com/en_us/blog/learn/cia-triad-confidentiality-integrity-availability.html
2. CIA Triad: Confidentiality, Integrity & Availability for Data Protection - Kiteworks, <https://www.kiteworks.com/risk-compliance-glossary/cia-triad/>
3. What is CIA Triad? - GeeksforGeeks, <https://www.geeksforgeeks.org/computer-networks/the-cia-triad-in-cryptography/>
4. Executive Summary — NIST SP 1800-26 documentation, <https://www.nccoe.nist.gov/publication/1800-26/VolA/index.html>
5. Bilgi Güvenliği (InfoSec) nedir? | Microsoft Güvenlik, <https://www.microsoft.com/tr-tr/security/business/security-101/what-is-information-security-infosec>
6. Cryptography'de CIA Üçlüsü. Ağ güvenliği hakkında en önemli ..., <https://thebo.medium.com/cryptographyde-cia-%C3%BC%C3%A7I%C3%BCs%C3%BC-25a77b53f02>
7. What is the CIA Triad? | Key Components and Examples - Delinea, <https://delinea.com/blog/what-is-the-cia-triad-key-components-and-examples>
8. CIA triad: Confidentiality, integrity, and availability - SailPoint, <https://www.sailpoint.com/identity-library/cia-triad>
9. The Importance of Defense in Depth - Datto, <https://www.datto.com/blog/defense-in-depth/>
10. What is Defense-in-Depth (DiD)? - Delinea, <https://delinea.com/what-is/defense-in-depth-did>
11. ab'16 - OpenConf Konferans Yönetim Sistemi - Akademik Bilişim, <https://ab.org.tr/ab16/ozet/310.html>
12. İş Güvenliği ve Savunma Derinliği Teorisi: Derinlemesine Bir Bakış | Ticaret Gazetesi, <https://ticaretgazetesi.com.tr/2024/07/04/is-guvenligi-ve-savunma-derinligi-teorisi-derinlemesine-bir-bakis/>
13. Defence in depth - Wikipedia, https://en.wikipedia.org/wiki/Defence_in_depth
14. Defense in depth (computing) - Wikipedia, [https://en.wikipedia.org/wiki/Defense_in_depth_\(computing\)](https://en.wikipedia.org/wiki/Defense_in_depth_(computing))
15. What is defense in depth? | Layered security - Cloudflare, <https://www.cloudflare.com/learning/security/glossary/what-is-defense-in-depth/>
16. Successful Cyberattack Vectors: Common Threats and How to Stop Them | BlackFog, <https://www.blackfog.com/successful-cyberattack-vectors-common-threats-and-how-to-stop-them/>
17. En yaygın saldırı vektörü: Çalışanların güvenlik açığı - B2B siber ..., <https://b2b-cyber-security.de/tr/En-yayg%C4%B1n-sald%C4%B1r%C4%B1-vekt%C3%B6r%C3%BC-zay%C4%B1f-nokta-%C3%A7al%C4%B1%C5%9Fan%C4%B1/>
18. 9 Common Cyber Attack Methods & How to Prevent Them | Balbix, <https://www.balbix.com/insights/attack-vectors-and-breach-methods/>
19. Siber güvenlik gündemi: 2023 istatistiklerinde en yaygın saldırılar, 2024 ve sonrası için öngörüler - T24, <https://t24.com.tr/yazarlar/betul-ertem-yildiz/siber-guvenlik-gundemi-2023-istatistiklerinde-en-yaygin-saldirilar-2024-ve-sonrasi-icin-ongoruler,42941>
20. 12 Most Common Types of Cyberattacks - CrowdStrike, <https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/common-cyberattacks/>
21. Siber Saldırı Nedir? - Corbado, <https://www.corbado.com/tr/glossary/siber-saldiri>
22. 16 Types of Cybersecurity Attacks and How to Prevent Them | HackerOne, <https://www.hackone.com/knowledge-center/16-types-cybersecurity-attacks-and-how-prevent-them>
23. Siber Saldırı Örnekleri: Hangi Türler Tehlikeli? - CyberSkillsHub, <https://cyberskillshub.com/siber-saldiri-ornekleri/>
24. What is Proactive Cybersecurity and Why Does it Matter - Threat Intelligence, <https://www.threatintelligence.com/blog/proactive-cybersecurity>
25. Proactive Cyber Defense: Move Beyond Reactive Cybersecurity | Fidelis Security, <https://fidelissecurity.com/threatgeek/network-security/proactive-cyber-defense-approach/>
26. Comparing Proactive vs. Reactive Cybersecurity in 2025, <https://www.sangfor.com/blog/cybersecurity/proactive-vs-reactive-cybersecurity>
27. Proactive vs. Reactive Security Hardening: Key Differences - Opinnate, <https://opinnate.com/proactive-vs-reactive-security-hardening-understanding-the-key-differences/>
28. Proactive VS. Reactive Cybersecurity - Think Tech Advisors, <https://thinktechadvisors.com/2020/01/proactive-vs-reactive-cybersecurity/>
- 29.



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

so - AVESIS, <https://avesis.gazi.edu.tr/resume/lessonmaterieldownload/hkaracan?key=1a3aba98-079e-4bd4-b578-659708c8e103> 35. Symmetric Encryption vs. Asymmetric Encryption: Which to Use and When - CBT Nuggets, <https://www.cbtnuggets.com/blog/technology/security/symmetric-encryption-vs-asymmetric-encryption> 36. Modern Şifreleme Yöntemleri (Simetrik & Asimetrik Şifreleme), <https://kerteriz.net/modern-sifreleme-yontemleri-simetrik-asimetrik-sifreleme/> 37. Simetrik ve Asimetrik Şifreleme Algoritmaları | by Hicran ÖZKAN - Medium, <https://medium.com/@hicranozkan/simetrik-ve-asimetrik-anahtar%C4%B1-%C5%9Fifreleme-algoritmalar%C4%B1-a60a4e0eb079> 38. Hash Fonksiyonu (Özetleme Fonksiyonu) ve Birthday Attack - Beyaz.Net, https://www.beyaz.net/tr/guvenlik/makaleler/hash_fonksiyonu_ozetleme_fonksiyonu_ve_birthday_attack.html 39. Hash (Özetleme) Fonksiyonları Nedir? | by Berkay Aşcıoğlu | Medium, <https://medium.com/@berkayascioglu/hash-%C3%B6zetleme-fonksiyonlar%C4%B1-nedir-2a468de6107f> 40. Hash Fonksiyonları - Blog - Erkan Erol, <https://erkanerol.github.io/post/hash-functions/> 41. ssojet.com, <https://ssojet.com/compare-hashing-algorithms/md5-vs-sha-256/#:~:text=MD5%20produces%20a%20128%2Dbit,mores%20resilient%20against%20such%20vulnerabilities> 42. MD5 vs SHA-256 - A Comprehensive Comparison - MojoAuth, <https://mojoauth.com/compare-hashing-algorithms/md5-vs-sha-256/> 43. JavaScript hashing speed comparison: MD5 versus SHA-256 - Daniel Lemire's blog, <https://lemire.me/blog/2025/01/11/javascript-hashing-speed-comparison-md5-versus-sha-256/> 44. What is a Birthday Attack? How It Works & Examples | Twingate, <https://www.twingate.com/blog/glossary/birthday%20attack> 45. Doğum Günü Saldırısı (Birthday Attack) - Mustafa OZLU, <https://mustafaozlu.com/hergunyenibirpaylasim.asp?p=48> 46. Birthday Attack Security Guide: Cryptographic Defense Essentials, <https://www.startupdefense.io/cyberattacks/birthday-attack> 47. Implementing Non-Repudiation in Your Security Strategy: Best Practices and Techniques, <https://securityscorecard.com/blog/implementing-non-repudiation-in-your-security-strategy-best-practices-and-techniques/> 48. e-İmza Nedir, Nasıl Kullanılır? - Türkiye Finans, <https://www.turkiyefinans.com.tr/tr-tr/blog/sayfalar/e-imza.aspx> 49. What is Non-repudiation in Cyber Security? | Bitsight, <https://www.bitsight.com/glossary/non-repudiation-cyber-security> 50. Dijital İmza Hakkında Tüm Merak Ettikleriniz — idenfit, <https://idenfit.com/blog/dijital-imza/> 51. Dijital İmza Nedir, Nasıl Kullanılır? - Innova, <https://www.innova.com.tr/blog/dijital-imza-nedir-nasil-kullanilir> 52. Non-Repudiation Explained - TrainACE - IT and Cybersecurity Training Blog, <https://blog.trainace.com/glossary/risk-management-crgc-certification-0> 53. Firewall Types and Delivery Methods - Cato Networks, <https://www.catonetworks.com/network-firewall/firewall-types/> 54. 5 Types of Firewalls: Which One Do You Need? - Check Point ..., <https://www.checkpoint.com/cyber-hub/network-security/what-is-firewall/5-types-of-firewalls-which-one-do-you-need/> 55. Firewall (Güvenlik Duvarı) Nedir, Nasıl Çalışır, Türleri Nelerdir? - Berqnet, <https://berqnet.com/blog/firewall-nedir> 56. WAF vs. Firewall: What are the differences? - Fastly, <https://www.fastly.com/learning/security/waf-vs-firewall-what-are-the-differences> 57. Web Application Firewall - OWASP Foundation, https://owasp.org/www-community/Web_Application_Firewall 58. WAF (Web Application Firewall) Nedir? WAF Türleri ve Özellikleri - Bulutistan Blog, <https://bulutistan.com/blog/waf-nedir/> 59. WAF solutions against OWASP Top 10 risks | FortiWeb 7.6.3 ..., <https://docs.fortinet.com/document/fortiweb/7.6.3/waf-solutions-against-owasp-top-10-risks/801792/waf-solutions-against-owasp-top-10-risks> 60. Forward Proxy Vs. Reverse Proxy Servers | JSCAPE, <https://www.jscape.com/blog/forward-proxy-vs-reverse-proxy> 61. medium.com, <https://medium.com/ortigan/forward-vs-reverse-proxies-understanding-their-role-in-network-architecture-63b6f22ad6cf#:~:text=Key%20Differences%20Between%20Forward%20and%20Reverse%20Proxies&text=2.,%2C%20security%2C%20and%20SSL%20termination> 62. Proxy Türleri, Özellikleri ve Hakkında Bilinmesi Gereken Her Şey - Planet VPN, <https://freenvpnplanet.com/tr/blog/proxy-turleri-ozellikleri-ve-hakkinda-bilinmesi-gereken-her-sey/> 63. Intrusion Detection Vs Prevention Systems: What's The Difference?, <https://purplesec.us/learn/intrusion-detection-vs-intrusion-prevention-systems/> 64. Saldırı Tespit ve Önleme Sistemleri (IDS/IPS) - ELFANET, <https://elfanet.com.tr/tr/main/article/saldiri-tespit-ve-onleme-sistemleri-ids-ips/138> 65. 1. Intrusion Detection and Prevention Systems - National Institute of Standards and Technology, https://tsapps.nist.gov/publication/get_pdf.cfm?pub_id=901146 66. IDS/IPS - Saldırı Tespit ve Önleme Sistemi - epati Siber Güvenlik, <https://www.epati.com.tr/tr/blog/ids-ips-saldiri-tespit-ve-onleme-sistemi/> 67. What are the Three Types of IDS? - Stamus Networks, <https://www.stamus-networks.com/blog/what-are-the-three-types-of-ids> 68. SIEM vs. SOAR: 4 Key Differences & Integrating SIEM with SOAR ..., <https://www.exabeam.com/explainers/soar/siem-vs-soar-4-key-differences-amp-integrating-siem-with-soar/> 69. What Is SOAR? - Palo Alto Networks, <https://www.paloaltonetworks.com/cyberpedia/what-is-soar> 70. What is SOAR (Security Orchestration, Automation, and Response)? - Balbix, <https://www.balbix.com/insights/what-is-security-orchestration-automation-and-response-soar/> 71. What is IEEE 802.1X Network Access Control? | Versitron, <https://www.versitron.com/blogs/post/the-key-features-of-ieee-802-1x-network-access-control> 72.



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

SynchroNet, <https://synchronet.net/inter-vlan-routing/> 79. VLAN Yapılandırılmalı Lokasyonlar Arası Routing Yapılandırma - Firat Boyan, <https://www.firatboyan.com/vlan-yapilandirmali-lokasyonlar-arasi-routing-yapilandirma.aspx> 80. Understanding DMZ and Firewall - SAP Help Portal, https://help.sap.com/docs/SAP_BUSINESSOBJECTS_MOBILE_FOR_IOS/843ee00512094cd68acca0323d67cfd77e0766306cbd1014a23cc679b0e91070.html 81. DMZ ağı nedir? Bu çalışmamda DMZ ağı üzerinde... | by Mustafa İkbāl Yaşar - Medium, <https://medium.com/@mustafaikbalyasar/dmz-a%C4%9F%C4%B1-nedir-1105c62c5228> 82. Dual Firewall vs Single Firewall DMZ: A Comprehensive Analysis ..., <https://tolumichael.com/dual-firewall-vs-single-firewall-dmz/> 83. What to Consider When Setting Up DMZ's Reverse Proxy & Firewall | JSCAPE, <https://www.jscape.com/blog/considerations-when-setting-up-your-dmz-s-reverse-proxy-and-firewall> 84. WLAN Nedir? Nasıl Çalışır? WLAN Güvenliği Nasıl Sağlanır? - Blog - Berqnet, <https://berqnet.com/blog/wlan> 85. What is a Wireless LAN Controller? - CBT Nuggets, <https://www.cbtnuggets.com/blog/technology/networking/how-to-stabilize-and-scale-wireless-network-architectures> 86. What is a Wireless LAN Controller? - Lightyear.ai, <https://lightyear.ai/tips/what-is-a-wireless-lan-controller> 87. The Basics of Networking | Network Elements | Wireless LAN Controllers (WLC), <https://it-learn.io/2023/01/15/the-basics-of-networking-network-elements-wireless-lan-controllers-wlc/> 88. Control and Provisioning of Wireless Access Points protocol - Wikipedia, https://en.wikipedia.org/wiki/Control_and_Provisioning_of_Wireless_Access_Points_protocol 89. en.wikipedia.org, https://en.wikipedia.org/wiki/Control_and_Provisioning_of_Wireless_Access_Points_protocol#:~:text=The%20Control%20And%20Provisioning%20of,known%20as%20wireless%20access%20points 90. RFC 5415: 2 of 6, p. 11 to 39 - Tech-Invite, <https://www.tech-invite.com/y50/tinv-ietf-rfc-5415-2.html> 91. CAPWAP encryption using DTLS - Cisco Community, <https://community.cisco.com/t5/wireless-mobility-knowledge-base/capwap-encryption-using-dtls/ta-p/3148917> 92. What is WPA3 vs. WPA2? - Portnox, <https://www.portnox.com/cybersecurity-101/wpa3/> 93. WPA2 vs WPA3: Key Difference in Wi-Fi Security Protocols, <https://io.hfcl.com/blog/wpa2-vs-wpa3/> 94. Difference between Site to Site VPN and Remote Access VPN ..., <https://www.geeksforgeeks.org/computer-networks/difference-between-site-to-site-vpn-and-remote-access-vpn/> 95. Site-to-Site vs. Client-to-Site VPNs: Key Differences and Use Cases - Symlex VPN, <https://symlexvpn.com/site-to-site-vs-client-to-site-vpn/> 96. The difference between Remote access vs. site-to-site VPN - t-Blog - Tekmart, <https://tekmart.co.za/t-blog/the-difference-between-remote-access-vs-site-to-site-vpn/> 97. VPN çeşitleri ve bunların kullanım zamanları - Surfshark, <https://surfshark.com/tr/blog/vpn-cesitleri> 98. VPN Hakkında Bilinmesi Gerekenler - F1 TEKNOLOJİ BILGISAYAR GUVENLIK SISTEMLERI SAN. VE TIC. A.Ş., <https://f1teknoloji.com.tr/vpn-hakkinda-bilinmesi-gerekenler/> 99. Comparing SSL/TLS and IPsec — Choosing the Right Protocol for Your Network Needs, <https://medium.com/@RocketMeUpCybersecurity/comparing-ssl-tls-and-ipsec-choosing-the-right-protocol-for-your-network-needs-423b9f4aa218> 100. IPsec vs. SSL VPNs: Comparing key differences - ConnectWise, <https://www.connectwise.com/blog/ssl-vs-ipsec-vpns> 101. What is the difference between SSL/TLS VPN and IPsec VPN, and which one should I use?, <https://www.webasha.com/blog/what-is-the-difference-between-ssl-tls-vpn-and-ipsec-vpn-and-which-one-should-i-use> 102. SSL VPN vs. IPSec: What Are the Differences? - Palo Alto Networks, <https://www.paloaltonetworks.com/cyberpedia/ipsec-vs-ssl-vpn> 103. IPsec (Internet Protocol Security) Nedir? IPsec ve SSL VPN'ler ..., <https://www.cozumpark.com/ipsec-internet-protocol-security-nedir-ipsec-ve-ssl-vpnler-arasindaki-fark/> 104. IP Security Protocol (ipsec) - IETF Datatracker, <https://datatracker.ietf.org/wg/ipsec/documents/> 105. IPsec vs SSL VPN | Hangi VPN Daha Güvenli? Katman, Kurulum, Kullanım Karşılaştırması!, <https://www.youtube.com/watch?v=NA5WZXLp9rw> 106. SSL VPN vs IPsec: A Comparison - NinjaOne, <https://www.ninjaone.com/blog/ssl-vpn-vs-ipsec/> 107. Related information for TLS - IBM, https://www.ibm.com/docs/ssw_ibm_i_74/rzain/rzainrelativeinfo.htm 108. RFC 4346 - The Transport Layer Security (TLS) Protocol Version 1.1 - IETF Datatracker, <https://datatracker.ietf.org/doc/html/rfc4346> 109. RFC 5246 - The Transport Layer Security (TLS) Protocol Version 1.2 - IETF Datatracker, <https://datatracker.ietf.org/doc/html/rfc5246> 110. RFC 2246 The TLS Protocol Version 1.0 - IETF, <https://www.ietf.org/rfc/rfc2246.txt> 111. Information on RFC 2246 - » RFC Editor, <https://www.rfc-editor.org/info/rfc2246> 112. Cybersecurity 101: What is Software-Defined Networking (SDN)? - Illumio, <https://www.illumio.com/cybersecurity-101/software-defined-networking> 113. Software-defined networking - Wikipedia, https://en.wikipedia.org/wiki/Software-defined_networking 114. The Benefits of Software-Defined Networking (SDN) Security, <https://blog.lumen.com/what-is-software-defined-networking-security/> 115. What is the difference between SD WAN vs MPLS? - Netify, <https://www.netify.com/learning/how-to-compare-sd-wan-vs-mpls/> 116. SD-WAN vs MPLS: Cost, Performance & Security Breakdown - Zscaler, Inc., <https://www.zscaler.com/zpedia/sd-wan-vs-mpls> 117. What's the difference between SD-Wan and MPLS? - Advantech, <https://www.advantech.com/en/resources/industry-focus/mastering-sd-wan-and-mpls-a-comprehensive-guide> 118. What are the differences between SD-WAN and SDN? - Palo Alto ...



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

Güvenliği Güçlendirme - inventiv, <https://inventiv.com.tr/tr/blog/zero-trust-sifir-guven-modeli-ile-kurumsal-siber-guvenligi-guclendirmeye> 127. What Is Microsegmentation? - Palo Alto Networks, <https://www.paloaltonetworks.com/cyberpedia/what-is-microsegmentation> 128. Cybersecurity 101: What is Lateral Movement? A Complete ... - Illumio, <https://www.illumio.com/cybersecurity-101/lateral-movement> 129. Prevent lateral compromise with micro-segmentation | Nomios Group, <https://www.nomios.com/news-blog/prevent-lateral-compromise-with-microsegmentation/> 130. Load Balancing Deep Dive: Algorithms, Types, And Use-Cases - StoneFly, <https://stonefly.com/resources/load-balancing-algorithms-types-use-cases/> 131. What is Load Balancing? Definition of Traffic Distribution - AWS, <https://aws.amazon.com/what-is/load-balancing/> 132. What is Load Balancing & How it Works (Complete Breakdown) - HAProxy Technologies, <https://www.haproxy.com/blog/what-is-load-balancing> 133. Explain how a Content Delivery Network (CDN) improves the performance of a website. - Red Hat Learning Community, <https://learn.redhat.com/t5/General/Explain-how-a-Content-Delivery-Network-CDN-improves-the-td-p/43565> 134. What Is a CDN (Content Delivery Network)? | How Do CDNs Work ..., <https://www.akamai.com/glossary/what-is-a-cdn> 135. CDN reliability and redundancy - Cloudflare, <https://www.cloudflare.com/learning/cdn/cdn-load-balance-reliability/> 136. How Do CDNs Help Prevent DDoS Attacks? | Prophaze Learning Center, <https://prophaze.com/learn/ddos/how-do-cdns-help-prevent-ddos-attacks/> 137. What is CDN Load Balancing? Benefits & Best Practices - IO River, <https://www.ioriver.io/terms/cdn-load-balancing> 138. Authentication, authorization, and accounting - Wikipedia, https://en.wikipedia.org/wiki/Authentication,_authorization,_and_accounting 139. What is Authentication, Authorization, and Accounting (AAA)?, <https://instasafe.com/glossary/what-is-authentication-authorisation-and-accounting-aaa/> 140. Authentication, Authorization, and Accounting For Developers | Auth0, <https://auth0.com/blog/authentication-authorization-and-accounting-for-developers/> 141. What Is Identity and Access Management (IAM)? - Styra, <https://www.styra.com/knowledge-center/what-is-identity-and-access-management-iam/> 142. Exam 300-715 topic 1 question 154 discussion - ExamTopics, <https://www.examttopics.com/discussions/cisco/view/92953-exam-300-715-topic-1-question-154-discussion/> 143. Network Authentication Protocols: RADIUS, TACACS+ ..., <https://www.geeksforgeeks.org/computer-networks/network-authentication-protocols-radius-tacacs/> 144. RADIUS vs TACACS+: What's the Difference? - InstaSafe, <https://instasafe.com/blog/radius-vs-tacacs-what-to-choose-for-your-enterprise/> 145. TACACS+ or Radius : r/networking - Reddit, https://www.reddit.com/r/networking/comments/pq03wv/tacacs_or_radius/ 146. AAA framework: TACACS+ vs RADIUS - YouTube, <https://www.youtube.com/watch?v=LXd2uP1qKDE> 147. TACACS vs RADIUS: The Better Authentication Method - Cloud ..., <https://www.cloudradius.com/tacacs-vs-radius-which-is-better-for-you/> 148. Comparing RADIUS vs. TACACS+: Differences, Benefits, and Use Cases - JumpCloud, <https://jumpcloud.com/blog/comparing-radius-vs-tacacs-whats-the-difference> 149. What is Multifactor Authentication (MFA) Implementation? - Palo Alto ..., <https://www.paloaltonetworks.com/cyberpedia/what-is-mfa-implementation> 150. What is Multi-Factor Authentication? - MFA Explained - AWS, <https://aws.amazon.com/what-is/mfa/> 151. Çok Faktörlü Kimlik Doğrulaması (MFA) | Microsoft Güvenlik, <https://www.microsoft.com/tr-tr/security/business/identity-access/microsoft-entra-mfa-multi-factor-authentication> 152. multi-factor authentication - Glossary | CSRC - NIST Computer Security Resource Center, https://csrc.nist.gov/glossary/term/multi_factor_authentication 153. What Are Multifactor Authentication (MFA) Examples and Methods? - Palo Alto Networks, <https://www.paloaltonetworks.com/cyberpedia/what-are-multi-factor-authentication-mfa-examples-and-methods> 154. What is Passwordless Authentication? Security, Solutions & Benefits - Passkeys, <https://www.passkeys.com/what-is-passwordless-authentication> 155. Passwordless Authentication with FIDO2 and WebAuthn | Frontegg, <https://frontegg.com/guides/passwordless-authentication-with-fido2-and-webauthn> 156. FIDO2 WebAuthn Powering Passwordless Authentication's Next Wave - Security Boulevard, <https://securityboulevard.com/2025/08/fido2-webauthn-powering-passwordless-authentications-next-wave/> 157. What is single sign-on? - Microsoft Entra ID, <https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/what-is-single-sign-on> 158. What is OpenID vs SAML? Find out the differences - Auth0, <https://auth0.com/intro-to-iam/saml-vs-openid-connect-oidc> 159. What is the difference between OpenID and SAML? - Stack Overflow, <https://stackoverflow.com/questions/7699200/what-is-the-difference-between-openid-and-saml> 160. SAML 2.0 - Wikipedia, https://en.wikipedia.org/wiki/SAML_2.0 161. What is SAML and how does SAML Authentication Work | Auth0, <https://auth0.com/blog/how-saml-authentication-works/> 162. SAML Single Sign-On (SSO) Flow - SecureAuth Product Docs, <https://docs.secureauth.com/ciam/en/saml-single-sign-on--sso--flow.html> 163. What's the Difference Between OAuth, OpenID Connect, and SAML? - Okta, <https://www.okta.com/identity-101/whats-the-difference-between-oauth-openid-connect-and-saml/> 164. OpenID Connect Authorization Code Flow | An Overview - Curity,



Dokümanlar uygulamasıyla düzenleyin

İnce ayarlar yapın, yorum yazın ve aynı anda düzenlemek için başkalarıyla paylaşın.

HAYIR, TEŞEKKÜRLER

UYGULAMAYI KULLAN

integration-with-amazon-route-53/ 170. Domain Controller Location | Microsoft Learn, <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/domain-controller-location> 171. How to verify that SRV DNS records have been created for a domain controller, <https://learn.microsoft.com/en-us/troubleshoot/windows-server/networking/verify-srv-dns-records-have-been-created> 172. Domain Controller Locator Process | gancrz, <https://gancrz.wordpress.com/2013/02/13/domain-controller-locator-process/> 173. How does Windows find/discover the Domain Controller when you log in? - Server Fault, <https://serverfault.com/questions/747157/how-does-windows-find-discover-the-domain-controller-when-you-log-in> 174. Locating domain controllers in Windows and Windows Server - Microsoft Learn, <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/dc-locator> 175. How to configure DNS dynamic updates in Windows Server ..., <https://learn.microsoft.com/en-us/troubleshoot/windows-server/networking/configure-dns-dynamic-updates-windows-server-2003>